

- Expediente N.º: **EXP202400072**

RESOLUCIÓN DE TERMINACIÓN DEL PROCEDIMIENTO POR PAGO VOLUNTARIO

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

ANTECEDENTES

PRIMERO: Con fecha 23 de enero de 2024, la Directora de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a **BANCO COOPERATIVO ESPAÑOL, S.A.** (en adelante la parte reclamada). Notificado el acuerdo de inicio y tras analizar las alegaciones presentadas, con fecha 5 de diciembre de 2024 se emitió la propuesta de resolución que a continuación se transcribe:

<<

Expediente N.º: **EXP202400072**

PROPUESTA DE RESOLUCIÓN DE PROCEDIMIENTO SANCIONADOR

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes:

ANTECEDENTES

PRIMERO:

El 13 de diciembre de 2022, se notificó brecha de datos personales de la entidad perteneciente al GRUPO CAJA RURAL: BANCO COOPERATIVO ESPAÑOL, S.A. con NIF **A79496055** (en adelante, BCE o la entidad) como responsable del tratamiento.

Hay que señalar que, como consecuencia de las notificaciones a la División de Innovación Tecnológica de esta Agencia de la brecha de datos personales en distintas Entidades del citado Grupo, entre las que se encuentra parte reclamada, relativas a un ciber-incidente, se ordenó a la Subdirección General de Inspección de Datos que se realizaran las oportunas investigaciones previas con el fin de determinar una posible vulneración de la normativa de protección de datos.

1. En un principio, las notificaciones de la brecha fueron realizadas por el encargado del tratamiento **RURAL SERVICIOS INFORMÁTICOS S.L.** (en lo sucesivo RSI), en relación con 19 entidades del Grupo:
2. Figuran como fechas de notificación inicial y de notificación adicional: 12/12/2022 y 10/01/2023.

3. No obstante, en fechas 13/12/2022, 14/12/2022 y 15/12/2022 se realizaron notificaciones de la brecha por otras 7 entidades del grupo, entre las que se encuentra la parte reclamada en su condición de responsables del tratamiento, a pesar de que el encargado del tratamiento es el mismo.

Los formularios de notificación de la brecha se acompañan del *Informe de Incidencia de Seguridad* elaborado en todos los casos por RSI, encargado del tratamiento.

- Fecha de detección de la brecha: 09/12/2022
- Fecha de ocurrencia de la brecha: 10/11/2022
- Resumen de la notificación:

(...)

- Tipología de datos afectados:

(...)

- Número total de clientes, con la condición de personas físicas que podrían haber sido potencialmente afectadas por la brecha: (...)

- Número de personas físicas cuyos datos se han visto efectivamente afectados por la brecha: (...)

- Número de afectados informados: ha comunicado la brecha a los afectados

SEGUNDO:

Como consecuencia de las notificaciones a la División de Innovación Tecnológica de esta Agencia de brecha de datos personales en distintas Entidades del GRUPO CAJA RURAL relativas a un ciber-incidente, mediante nota interior de la Directora de la AEPD se ordenó a la Subdirección General de Inspección de Datos que realizase las oportunas investigaciones previas con el fin de determinar una posible vulneración de la normativa de protección de datos.

Durante las presentes actuaciones se han investigado las siguientes entidades:

(...)

Al objeto de investigar la ocurrencia de los hechos descritos, en fecha 29/03/2023 se realiza una solicitud de información a RSI. La respuesta al requerimiento tiene entrada en fecha 14/04/2023.

En fechas 12/05/2023 y 27/09/2023 se solicita a RSI ampliación de la información aportada y en fechas 26/05/2023 y 11/10/2023 tienen entrada en la sede electrónica de la AEPD sendas respuestas.

Con el fin de introducir las aplicaciones comprometidas en la brecha que se van a referenciar a lo largo del presente informe, se reproduce, a continuación, la descripción

que se recoge en la documentación aportada por RSI en el marco de las actuaciones de investigación:

(...)

Asimismo, RSI, en su escrito de fecha de entrada en la AEPD el 14/04/2023, manifiesta:

(...)

Con relación al número de usuarios a los que se da servicio la Banca Electrónica y los modos de acceso:

(...)

Respecto de la cronología de los hechos. Acciones tomadas con objeto de minimizar los efectos adversos y medidas adoptadas para su resolución final

En el Informe de Análisis de Incidente de Seguridad que acompaña al formulario de notificación de la brecha se recoge:

(...)

Desde las áreas de RSI responsables de fraude y del desarrollo de la NBE se comienza la investigación para conocer cómo se había producido el fraude.

(...)

1. Las medidas mitigadoras llevadas a cabo durante el día 7 y 9 de diciembre fueron:

(...)

Respecto de las causas que hicieron posible la brecha

- Factores que contribuyeron a que se produjera la incidencia

(...)

Respecto de los datos afectados

La información a la que se habría podido acceder durante la brecha engloba datos personales, de contacto y financieros:

“[...]”

(...)

En el *Informe de Análisis de Incidente de Seguridad* que acompaña al formulario de notificación de la brecha se analiza el tipo de información que ha sido extraída por el

ciberdelincuente y el impacto en los clientes personas físicas, teniendo en cuenta, entre otras, las siguientes variables:

(...)

Durante el marco de las actuaciones de investigación se solicita a RSI información adicional relativa a los datos de los clientes que no disponen de Acuerdo de Banca Electrónica a los que los usuarios comprometidos en la brecha pudieron haber accedido. RSI en su escrito de respuesta, manifiesta que:

(...)

Respecto del contrato de encargado del tratamiento

RSI aporta el *Registro de Actividades del Tratamiento* de RSI e indica que el tratamiento en donde se encuentra la operativa de Banca Electrónica es el tratamiento de *Gestión de Clientes*, tratamiento donde RSI actúa como encargado.

RSI aporta como el *Acuerdo de modificación de la cláusula de protección de datos de los contratos de prestación de servicios suscritos entre, CAJA RURAL DE JAÉN, BARCELONA Y MADRID, S.C.C.* (responsable del tratamiento), y RSI (encargado del tratamiento).

RSI señala que este Acuerdo se firmó con las Entidades en el año 2018 y que es el mismo modelo para todas ellas.

En el Acuerdo se recoge, en otros aspectos:

- El objeto del Acuerdo es establecer el régimen jurídico aplicable al tratamiento de los datos personales que se traten o pudieran tratar por el encargado del tratamiento, en virtud de los contratos de prestación de servicios que se suscriban entre las partes, y que están bajo la titularidad y control del responsable del tratamiento.
- El encargado del tratamiento se obliga a tratar los datos de acuerdo con las instrucciones del responsable del Tratamiento.
- El encargado del tratamiento aplicará medidas técnicas y organizativas de seguridad para garantizar un nivel de seguridad adecuado.
- Se autoriza al encargado a subcontratar a las empresas reflejadas en el Anexo A del Acuerdo – *Subcontrataciones*. El subcontratista, que también tiene la condición de encargado del tratamiento, está obligado igualmente a cumplir las obligaciones establecidas en el Acuerdo para el encargado del tratamiento y las instrucciones que dicte el responsable.

Respecto de las medidas de seguridad

RSI señala que la planificación del desarrollo de la NBE se extiende desde 2019 hasta 2022 y que durante el mes de diciembre de 2019 se realiza el análisis de riesgos de la NBE tanto de la versión Web como de la App. Se analizan los siguientes ámbitos:

(...)

Del tratamiento *Gestión de Clientes*, RSI señala que se ha realizado un análisis de riesgos en materia de protección de datos por parte del Delegado de Protección de Datos. Este análisis se realiza con una primera revisión del listado de las amenazas y

la valoración sobre si aplican o no al tratamiento, aporta *el cuestionario de valoración de amenazas* y, una segunda parte, en donde se realiza el análisis de riesgos conforme a la metodología de análisis de riesgos de RSI. Se aporta el resultado de dicho análisis.

RSI indica que, (...) y que en cumplimiento de esta línea de trabajo se han realizado tres evaluaciones de seguridad sobre Ruralvía Clásica cuyos informes aporta:

- Informe realizado por la empresa *****EMPRESA.1**, sobre auditoría de aplicación web, fechado a 28/02/2022.
- Informe realizado por la empresa *****EMPRESA.1**, sobre auditoría de aplicación web, fechado a 28/04/2022.
- Informe realizado por la empresa *****EMPRESA.2**, evaluación continua que refleja las pruebas realizadas entre el 01/10/2021 y el 30/04/2023, en donde todas las vulnerabilidades críticas se encuentran cerradas.

Se aporta también el informe elaborado por el departamento de Ciberseguridad de RSI donde se relacionan las tres evaluaciones de seguridad realizadas por un tercero y el estado de resolución de las vulnerabilidades detectadas.

Asimismo, RSI acredita que, (...) se realizó en el mes de junio de 2022 una auditoría de hacking ético por un proveedor externo. Adjunta el informe de la auditoría y manifiesta:

(...)

RSI, en su escrito de fecha de entrada en la AEPD el 11/10/2023, explica:

(...)

Asimismo, se relacionan las auditorías que se han realizado con posterioridad a las comentadas en los anteriores requerimientos de información en cumplimiento del plan del fraude:

(...)

De igual modo, se facilita la última auditoría de cumplimiento de las medidas de seguridad (...) para cumplir con el Reglamento Delegado (...) siendo el periodo auditado del 15/12/2021 a 15/12/2022. El Informe está fechado a 15/12/2022. En concreto, se centró en la revisión de la información asociada a las medidas de seguridad relativas a las medidas de autenticación reforzada sobre los distintos canales y servicios de pago ofrecidos por RSI. Se aporta *el Informe de Auditoría* realizado por la firma *****EMPRESA.3**.

Para subsanar las vulnerabilidades detectadas conforme al nivel de cumplimiento con la *****NORMA.1** se procede a la realización de un plan de acción por parte de RSI. Se aporta el *Plan de Acción* con el estado actual.

(...)

Motivo por el cual las medidas de seguridad implantadas no han impedido el incidente.

(...)

Medidas técnicas y organizativas adoptadas para evitar, en lo posible, incidentes como el sucedido.

Además de las medidas descritas anteriormente, RSI traslada en su escrito *Contestación Reclamación AEPD*:

(...)

RSI, en su escrito de fecha de entrada en la AEPD 11/10/2023, detalla el funcionamiento de estos controles:

(...)

A lo largo del mes de febrero del 2023 se llevaron a cabo las siguientes acciones:

(...)

Información sobre la recurrencia de estos hechos y número de eventos análogos acontecidos en el tiempo

RSI manifiesta que estos hechos no son recurrentes, siendo esta la primera ocasión en la que se han dado.

Asimismo, señala que no han tenido noticias por parte de su servicio (...) de publicación de datos en la *darkweb*.

TERCERO:

Con fecha 23 de enero de 2024, la Directora de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a BCE, por la presunta infracción del artículo 5.1.f) del RGPD, con un sanción inicial de 15.000€, concediendo un plazo de diez días para presentar alegaciones.

Este acuerdo de inicio, que se notificó a BCE conforme a las normas establecidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (LPACAP), fue recogido en fecha 25/01/2024, como consta en el acuse de recibo que obra en el expediente.

CUARTO:

Con fecha 31/1/2024, BCE presenta un escrito a través del cual solicita la ampliación del plazo para aducir alegaciones y que se le facilite copia del expediente.

QUINTO:

Con fecha 5/2/2024, el órgano instructor del procedimiento acuerda la ampliación de plazo instada hasta un máximo de 10 días, a partir del día siguiente a aquel en el que reciba la copia del expediente y que se le remita a BCE copia del expediente.

El citado acuerdo se notifica a BCE en fecha 5/2/2024 como consta en el acuse de recibo que obra en el expediente.

SEXTO:

Con fecha 22/2/2024 el instructor del expediente remitió al encargado del tratamiento escrito en el que le señalaba que *“Dado que gran parte de la documentación obrante en el mismo ha sido suministrada por RSI a través del Registro Electrónico General, se le relacionaban agrupados por fechas, los números de registro de los documentos presentados, para que en el plazo de 10 días hábiles, comunicara si existían documentos, o partes de documentos, que considerara que no debían facilitarse a la parte reclamada, por concurrir motivos relacionados con el secreto comercial, protección de datos personales u otros.”*

SÉPTIMO:

Con fecha 22/2/2024 el encargado del tratamiento manifestaba *“que en lo que se refiere a su traslado a la parte reclamada, considera mi mandante que no le corresponde a la misma, sino a la AEPD valorar la licitud de dicho traslado y/o, en su caso, la existencia de cualesquiera impedimentos o limitaciones pueda establecer la normativa aplicable”*.

OCTAVO:

Con fecha 16/4/2024 el instructor del procedimiento remitió a la parte reclamada dos escritos: uno, dando traslado a la copia del expediente administrativo de conformidad con lo señalado en el artículo 53.1 a) de la LPCAP y, de forma independiente un segundo en el que se facilita la clave y el hash que le permitirá acceder a la documentación incluida en el soporte físico.

NOVENO:

Con fecha 30/4/2024 BCE presentó escrito de alegaciones formulando, en síntesis, las siguientes:

1. Que se acumulen todos los procedimientos (26) abiertos a las entidades pertenecientes al Grupo Caja Rural por existir intima conexión e identidad sustancial; la ausencia de culpabilidad de la parte reclamada en el presente caso;
2. La afectación de los principios del derecho sancionador como consecuencia de la interpretación efectuada por la AEPD;
3. Inexistencia de vulneración del artículo 32.1 del RGPD;
4. Inexistencia de vulneración del artículo 5.1.f) del RGPD; I
5. Inexistencia de vulneración del artículo 33 del RGPD;
6. Vulneración del principio de proporcionalidad en la determinación de las sanciones;
7. Que se archiven las actuaciones o se acuerde una sanción de apercibimiento o una minoración significativa de la sanción.

DÉCIMO:

Con fecha 21/10/2024, se acordó la apertura de un período de práctica de pruebas, acordándose las siguientes:

- Dar por reproducidos a efectos probatorios la reclamación interpuesta por la reclamante y su documentación, los documentos obtenidos y generados por los Servicios de Inspección que forman parte del expediente.
- Dar por reproducido a efectos probatorios, las alegaciones al acuerdo de inicio presentadas por el reclamado y la documentación que acompaña.
- Solicitar a la parte reclamada para que aporte documentación acreditativa de que, en su caso, había encargado o dado instrucciones a su encargado del tratamiento para la notificación a la AEPD de la brecha de datos personales objeto del presente expediente sancionador y la acreditación tanto del citado encargo como de los términos contenidos en el mismo y expresión de la fecha del mismo.

Con fecha 5/11/2024 la parte reclamada dio respuesta a la prueba practicada cuyo contenido obra en el expediente.

UNDÉCIMO:

Se acompaña como anexo relación de documentos obrantes en el procedimiento.

De las actuaciones practicadas en el presente procedimiento, han quedado acreditados los siguientes,

HECHOS PROBADOS

PRIMERO:

Tal y como consta en la escritura de elevación a público de acuerdos sociales otorgada por la entidad Banco Cooperativo Español S.A, número de protocolo (...).

Asimismo, tal y como disponen en sus Estatutos, goza de personalidad jurídica propia y plena capacidad de obrar.

Los Estatutos de BCE se encuentran también publicados en su página web

<https://www.bancocooperativo.es/es/particulares/sobre-entidad>

SEGUNDO:

Con fecha 30/4/2024 se presentó por BCE junto con el escrito de alegaciones al acuerdo de inicio "Acuerdo de modificación de la cláusula de protección de datos de los contratos de prestación de servicios suscrito entre BCE y Rural Servicios Informáticos, S.L." de fecha 13/9/2018 y firmada en representación de la BCE por **A.A.A. y B.B.B., (...).**

En dicho Acuerdo se especifica:

"DE UNA PARTE, BANCO COOPERATIVO ESPAÑOL, S.A. (en adelante, Responsable del Tratamiento), (...)

Y

DE OTRA PARTE, RURAL SERVICIOS INFORMATICOS, S.L. (en adelante, Encargado del Tratamiento), (...)"

En dicho acuerdo se indica que,

“El objeto del Acuerdo es establecer el régimen jurídico aplicable al tratamiento de los datos personales que se traten o pudieran tratar por el encargado del tratamiento, en virtud de los contratos de prestación de servicios que se suscriban entre las partes, y que están bajo la titularidad y control del responsable del tratamiento.

Los tratamientos de datos previstos son aquellos estrictamente necesarios para la prestación de los servicios prestados en el contrato principal. Se definen los tratamientos que se podrían llevar a cabo por RSI, la tipología de la información a tratar y las categorías de los interesados cuyos datos podrían ser tratados”.

En el propio Acuerdo se indica, en el apartado 3 relativo a las Obligaciones del Encargado del Tratamiento, que:

“El Encargado del Tratamiento y todo su personal se obliga a:

a) Utilizar los datos personales objeto del tratamiento, o los que recoja para su inclusión, sólo para la finalidad objeto de este encargo. En ningún caso podrá utilizar los datos para otro fin distinto, ya sea propio, o de terceros. Para llevar a cabo cualquier otra actividad que tenga por objeto el tratamiento o utilización de los ficheros de datos del Responsable del Tratamiento, será necesario el consentimiento previo y por escrito del mismo.

b) Tratar los datos de acuerdo con las instrucciones del responsable del Tratamiento. (...)

(...)”

En cuanto a la notificación de las “violaciones de la seguridad de datos” se especifica en el apartado 3.3 que:

“El Encargado del Tratamiento notificará al Responsable del Tratamiento, sin dilación indebida, y en cualquier caso, antes del plazo máximo de 36 horas, y a través del DPD, las violaciones de la seguridad de los datos personales a su cargo de las que tenga conocimiento, juntamente con toda la obligación relevante para la documentación y comunicación de la incidencia. (...)”.

Añade el apartado 3.4 relativo a las medidas de seguridad que:

“El encargado del tratamiento, de acuerdo con lo establecido en el artículo 32, aplicará aquellas medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo de tratamiento detectado en cada caso, considerando el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgo de probabilidad y gravedad variables para los derechos de las personas físicas en cada momento.

En cualquier caso, deberá implantar mecanismos equivalentes a los utilizados por el Responsable de Tratamiento para:

- a. *Garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento.*
- b. *Restaurar la disponibilidad y el acceso a los datos personales de forma rápida, en caso de incidente físico o técnico.*
- c. *Verificar, evaluar y valorar, de forma regular, la eficacia de las medidas técnicas y organizativas implantadas para garantizar la seguridad del tratamiento.*
- d. *Seudonimizar y cifrar los datos personales, en su caso.*

Las medidas técnicas y organizativas a implantar por el Encargado, son las reflejadas en el Anexo B del presente acuerdo -Medidas de Seguridad."

Se autoriza al encargado a subcontratar a las empresas reflejadas en el Anexo A del Acuerdo – *Subcontrataciones*. El subcontratista, que también tiene la condición de encargado del tratamiento, está obligado igualmente a cumplir las obligaciones establecidas en el Acuerdo para el encargado del tratamiento y las instrucciones que dicte el responsable.

En cuanto a las obligaciones del responsable del tratamiento se indica en el apartado 4 del Acuerdo:

"Corresponde al responsable del tratamiento:

- a) *"Entregar al Encargado del Tratamiento los datos necesarios para la prestación del servicio.*
- b) *En caso de que legalmente resulte exigible, realizar una evaluación de impacto en la protección de datos personales de las operaciones de tratamiento a realizar por el Encargado del Tratamiento.*
- c) *Realizar las consultas previas que corresponda.*
- d) *Velar, de forma previa y durante todo el tratamiento, por el cumplimiento de RGPD, por parte del Encargado del Tratamiento.*
- e) *Supervisar el tratamiento, incluida la realización de inspecciones y auditorías."* (el subrayado es nuestro)

En el apartado 5 se identifica el DPD del encargado y del responsable del tratamiento respectivamente.

Respecto de la BCE (...):

*"Identificación **A.A.A.***

*Contacto *****EMAIL.1.***

Respecto de la *RURAL SERVICIOS INFORMATICOS, S.L.* consta como DPD:

*"Identificación **C.C.C.***

*Contacto *****EMAIL.2***

Dispone el apartado 6 del Acuerdo sobre la "Responsabilidad" que,

“Si el Encargado, o en su caso, los contratistas, infringen este Acuerdo o la normativa vigente al determinar los fines y medios del tratamiento, serán considerados responsables del tratamiento con respecto a dicho tratamiento.

En caso de que una autoridad de control sancionase al Responsable del Tratamiento como consecuencia directa, de que el Encargado del Tratamiento no haya cumplido las estipulaciones de este Acuerdo, el Encargado indemnizará al Responsable del Tratamiento en lo estipulado en la cláusula de responsabilidad del contrato marco vigente entre las partes” (el subrayado es nuestro)

TERCERO:

En el “Acuerdo de modificación de la cláusula de protección de datos de los contratos de prestación de servicios”, suscrito entre BCE y RSI, firmado en Madrid el 13/9/2018 consta *Anexo B- Medidas de Seguridad al Acuerdo de modificación de la cláusula de protección de datos de los contratos de prestación de servicios*, en el que se indica que RSI cuenta con las siguientes certificaciones:

(...)

Asimismo, en el “Acuerdo de modificación de la cláusula de protección de datos de los contratos de prestación de servicios”, se indica que RSI cuenta con las siguientes medidas:

(...)

CUARTO:

Con fecha 12 de diciembre de 2022 se notificó una brecha de datos personales de CAJA RURAL BCE a la División de Innovación Tecnológica de esta Agencia, con número de entrada REGAGE22e00057420153. Esta notificación fue remitida por RSI, encargado de tratamiento de BCE. Adjunta a esta notificación se remite “*Informe de análisis de incidencia de seguridad*”.

Con fecha 12/01/2023, BCE realizó una notificación adicional a la descrita en el apartado anterior, con número de entrada REGAGE23e00002252732.

QUINTO:

La BCE contaba con la aplicación de banca electrónica denominada Ruralvía Clásica a los efectos de prestar servicios bancarios online a sus clientes.

(...)

Con fecha 14 de abril de 2023, contestando al requerimiento efectuado por la AEPD, se contesta por RSI que:

(...)

SEXTO:

En relación con el establecimiento de un banner establecido en la aplicación Ruralvía Clásica que enlazaba con la nueva aplicación NBE y su funcionamiento, en el “Informe de Análisis de Incidente de Seguridad”, de fecha 9 de diciembre de 2022, que RSI aportó en relación con la brecha de datos personales de BCE, se indica:

(...)

Asimismo, con fecha 14 de abril de 2023, contestando al requerimiento efectuado por la AEPD en el marco de las actuaciones previas de investigación, se contesta por RSI que:

(...)

RSI, en su escrito de fecha de entrada en la AEPD el 11 de octubre de 2023, Contestación 3 Reclamación AEPD de la entrada REGAGE23e00068900170, indica que,

(...)

SÉPTIMO:

(...)

Con fecha 14 de abril de 2023, contestando al requerimiento efectuado por la AEPD en el marco de las actuaciones previas de investigación, se aportó un documento 9 denominado “Auditoría de aplicación web” en la que se indica (...).

OCTAVO:

(...)

NOVENO:

En cuanto cómo se ha producido la brecha de datos personales, con fecha 14 de abril de 2023, RURALVÍA, en respuesta al requerimiento de información formulado por esta Agencia, afirma lo siguiente,

(...)

Asimismo, en el “Informe de Análisis de Incidente de Seguridad Informe Final”, de fecha 30 de diciembre de 2022, que RSI aportó en relación con la brecha de datos personales de BCE, se indica en el epígrafe 1.4.2, *¿Cómo se detectó el problema o cómo ha sucedido?*, que:

(...)

DÉCIMO:

Asimismo, en el “Informe de Análisis de Incidente de Seguridad Informe Final”, de fecha 30 de diciembre de 2022, que RSI aportó en relación con la brecha de datos personales de BCE, en el epígrafe 1.4.1, “¿Qué ha sucedido?”, se explica que se produce la brecha de datos personales por una vulnerabilidad (...), indicando que:

(...)

DÉCIMO PRIMERO:

Respecto del patrón de ataque utilizado por el ciberdelincuente, con fecha 14 de abril de 2023, contestando al requerimiento efectuado por la AEPD en el marco de las actuaciones previas de investigación por RSI, se indica que,

(...)

Idéntica previsión se contiene en el apartado 1.4.2. del “Informe de Análisis de Incidente de Seguridad Informe Final”, de fecha 30 de diciembre de 2022, que RSI aportó en relación con la brecha de datos personales de BCE.

DÉCIMO SEGUNDO:

Respecto de las causas que permitieron la brecha de datos personales, en el “Informe de Análisis de Incidente de Seguridad Informe Final”, de fecha 30 de diciembre de 2022, que RSI aportó en relación con la brecha de datos personales de BCE se indica, en el epígrafe 3, “Análisis de causas”, que:

(...)

DÉCIMO TERCERO:

En respuesta al requerimiento de información formulado por la AEPD en el marco de las actuaciones previas de investigación, RSI contesta el 26 de mayo de 2023 aportando como documento 8 un correo electrónico de 28 de septiembre de 2022, antes de producirse el mayor volumen de accesos (entre el 10 de noviembre y el 23 del mismo mes) y detectarse la brecha de datos personales, enviado por (...).

En idéntico sentido, como se ha indicado, con fecha 14 de abril de 2023, contestando al requerimiento efectuado por la AEPD en el marco de las actuaciones previas de investigación, se contesta por RSI que,

(...)

Con fecha 14 de abril de 2023, contestando al requerimiento efectuado por la AEPD en el marco de las actuaciones previas de investigación, se aportó un documento 9 denominado “Auditoría de aplicación web”, en el que se indicaba que,

(...)

DÉCIMO CUARTO:

Con fecha 14 de abril de 2023, contestando al requerimiento efectuado por la AEPD en el marco de las actuaciones previas de investigación, se aportó un documento 9 denominado “Auditoría de aplicación web”, en la que se examinaba ***HERRAMIENTA.1.

(...)

DÉCIMO QUINTO:

En cuanto a la detección de la brecha de datos personales, en el “Informe de Análisis de Incidente de Seguridad Informe Final”, de fecha 30 de diciembre de 2022, que RSI aportó en relación con la brecha de datos personales de BCE, se indica en el epígrafe 1.4.1, “¿Qué ha sucedido?”, que:

(...)

Por tanto, si bien la brecha se detecta el 7 de diciembre de 2022, se constatan accesos anteriores a dicha fecha, constando que el mayor volumen de accesos se produce entre el 10 de noviembre y el 23 de noviembre de 2022.

Respecto de las medidas adoptadas el 23 de noviembre de 2022, el documento precitado indica que,

(...)

Por lo tanto, dichas medidas se adoptan antes de que se detectara la brecha de datos personales (el 7 de diciembre de 2022) y como consecuencia de las actuaciones para incrementar la seguridad de la banca electrónica.

DÉCIMO SEXTO:

En cuanto a las medidas mitigadoras aplicadas tras la brecha de datos personales, en el “Informe de Análisis de Incidente de Seguridad Informe Final”, de fecha 30 de BCE, señala que,

(...)

DÉCIMO SÉPTIMO:

Con posterioridad, en el marco de la definitiva implantación de la nueva aplicación NBE se llevan a cabo una serie de acciones, constando en el “Informe de Análisis de Incidente de Seguridad Informe Final”, de fecha 30 de diciembre de 2022, que RSI aportó en relación con la brecha de datos personales de BCE,

(...)

DÉCIMO OCTAVO:

Respecto de los datos personales a los que se había tenido acceso por el atacante, en el “Informe de Análisis de Incidente de Seguridad Informe Final”, de fecha 30 de diciembre de 2022, que RSI aportó en relación con la brecha de datos personales de BCE, se indican cuáles son los datos personales a los que se habría accedido,

(...)

DÉCIMO NOVENO:

Los formularios de notificación de la brecha que se acompañan del Informe de Incidencia de Seguridad elaborado en todos los casos por RURAL SERVICIOS INFORMÁTICOS, S.L., encargado del tratamiento, tal y como consta en el informe de actuaciones previas de investigación de 27 de noviembre de 2023, determinan que el número de afectados por la brecha de datos personales de la BCE es de 18 clientes.

VIGÉSIMO:

Durante el período de práctica de la prueba a que se refiere el Antecedente de Hecho Décimo, BCE aportó correo electrónico remitido autorizando la comunicación de la brecha al encargado del tratamiento (RSI), para la notificación de la brecha a la AEPD:

De: (...) bce Enviado: miércoles, 14 de diciembre de 2022 11:56

Para: DPO Entidades ; (...)

Asunto: RE: INCIDENTE RURALVÍA 0198 Buenos tardes **D.D.D.**, 5/11/24, 10:21

RV: INCIDENTE RURALVÍA 0198: **E.E.E.** –

*(...)Muchas gracias por vuestro correo. Comentado con **F.F.F.** y revisado el modelo de comunicación que habéis remitido a la Agencia, solicitamos la comunicación de la brecha de seguridad para Banco Cooperativo Español. continuación, os enviaré los datos que me habéis solicitado (...) de la Entidad.*

*En relación a la comunicación de la misma a los clientes afectados, esperamos que nos enviéis el borrador de la carta para su revisión y en su caso comunicación a nuestros clientes, que haremos, según me han indicado **F.F.F.**, nosotros mismos. Tengo pendiente revisar el informe de la incidencia de seguridad que habéis realizado. En cuanto pueda hacerlo, os digo algo.*

*Muchas gracias y saludos, **E.E.E.***

VIGÉSIMO PRIMERO:

De acuerdo con la documentación aportado por BCE en las alegaciones, el volumen de negocio (margen bruto) de BCE durante el ejercicio de 2022 asciende a 89.518.000 € euros.

FUNDAMENTOS DE DERECHO

I Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), es competente para iniciar y resolver este procedimiento la Directora de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *"Los procedimientos tramitados por la Agencia Española de Protección de Datos se regirán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos."*

II Cuestiones Previas

A continuación, se detalla la relación de los conceptos jurídicos relevantes para esta Propuesta de Resolución, de conformidad con las definiciones del artículo 4 del RGPD (se subrayan las partes relevantes):

"Artículo 4 Definiciones

A efectos del presente Reglamento se entenderá por:

(...)

1) «datos personales»: toda información sobre una persona física identificada o identificable («el interesado»); se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona;

(...)

2) «tratamiento»: cualquier operación o conjunto de operaciones realizadas sobre datos personales o conjuntos de datos personales, ya sea por procedimientos automatizados o no, como la recogida, registro, organización, estructuración, conservación, adaptación o modificación, extracción, consulta, utilización, comunicación por transmisión, difusión o cualquier otra forma de habilitación de acceso, cotejo o interconexión, limitación, supresión o destrucción;

El tratamiento ha consistido en este caso en un conjunto de operaciones para la extracción y consulta de los datos personales de los interesados.

7) «responsable del tratamiento» o «responsable»: la persona física o jurídica, autoridad pública, servicio u otro organismo que, solo o junto con otros, determine los fines y medios del tratamiento; si el Derecho de la Unión o de los Estados miembros

determina los fines y medios del tratamiento, el responsable del tratamiento o los criterios específicos para su nombramiento podrá establecerlos el Derecho de la Unión o de los Estados miembros;

La persona jurídica que determina los fines y medios del tratamiento es BCE, como prestador de servicios bancarios y los interesados son este caso los clientes que están vinculados con la entidad bancaria mediante un contrato. BCE recaba los datos de los clientes y decide sobre los fines y medios del conjunto de operaciones realizadas sobre datos personales por procedimientos automatizados.

8) «*encargado del tratamiento*» o «*encargado*»: la persona física o jurídica, autoridad pública, servicio u otro organismo que trate datos personales por cuenta del responsable del tratamiento;
(...)

BCE ha encargado a RURALVÍA S.L., mediante contrato de fecha 13/9/2018 la ejecución de las medidas de seguridad necesarias para el conjunto de operaciones automatizadas para el tratamiento de los datos personales de los clientes, en el marco de sus contratos de servicios bancarios.

12) «*violación de la seguridad de los datos personales*»: toda violación de la seguridad que ocasione la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos;

Se ha producido una violación de la seguridad de los datos personales, por el acceso no autorizado de un tercero (un hacker) a los datos personales de los clientes de BCE. La entidad realiza esta actividad en su condición de responsable del tratamiento, dado que es quien determina los fines y los medios relacionados con el tratamiento de los datos de carácter personal, en virtud del artículo 4.7 del RGPD. De modo que, si decide el “*por qué*” y el “*como*” deberán tratarse los datos personales, debe asumir su responsabilidad.

Además, el responsable del tratamiento se debe encargar también de aplicar las medidas técnicas y organizativas que garanticen la seguridad de los datos personales al llevar a cabo el tratamiento. Y ser capaz de demostrar el cumplimiento RGPD y de la LOPDGDD.

En el presente caso, consta un incidente de seguridad, categorizado como una brecha de datos personales, habiéndose producido un acceso indebido a datos de carácter personal.

Hay que señalar que la identificación de una brecha de datos personales no implica la imposición de una sanción de forma directa por esta Agencia, ya que es necesario analizar la diligencia de responsables y encargados y las medidas de seguridad aplicadas.

Entre los principios del tratamiento previstos en el artículo 5 del RGPD, la integridad y confidencialidad de los datos personales se garantiza en el apartado 1.f). Por su parte, la seguridad de los datos personales viene regulada en los artículos 32 y 33 del

RGPD, que reglamentan la seguridad del tratamiento, la notificación a la autoridad de control, así como la comunicación al interesado, respectivamente.

Como se señalaba con anterioridad, se presume que el responsable del tratamiento es la entidad que tiene la verdadera capacidad para ejercer el control sobre los datos, quien determina el por qué y el cómo deberán tratarse los datos.

III Descripción de la brecha de datos personales

La BCE contaba con la aplicación de banca electrónica denominada Ruralvía Clásica a los efectos de prestar servicios bancarios on line a sus clientes.

Para que un cliente entrara en la aplicación Ruralvía Clásica y abriera sesión necesitaba introducir su identificador, su contraseña y su NIF.

(...)

IV Infracción del artículo 5.1.f) del RGPD.

El artículo 5.1.f) *“Principios relativos al tratamiento”* del RGPD establece:

“1. Los datos personales serán:

(...)

f) tratados de tal manera que se garantice una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas («integridad y confidencialidad»).

(...)”

Los hechos puestos de manifiesto en este procedimiento son constitutivos de una brecha de datos personales consistente en una pérdida de confidencialidad de los datos personales, considerando que se ha vulnerado la normativa en materia de protección de datos de carácter personal. Los presentes hechos tienen como reclamado al responsable del tratamiento, BCE, tal y como se determina en los hechos probados.

Así, tal y como consta en el hecho probado décimo séptimo, respecto de los datos personales a los que se había tenido acceso por el atacante, en el “Informe de Análisis de Incidente de Seguridad Informe Final”, de fecha 30 de diciembre de 2022, indica que,

(...)

Si bien la brecha de datos personales se detecta el 7 de diciembre de 2022, se constatan accesos anteriores a dicha fecha, constando que el mayor volumen de accesos se produce entre el 10 de noviembre y el 23 de noviembre de 2022.

En este sentido, en el citado informe de 30 de diciembre de 2022, tal y como consta en el hecho probado octavo y décimo cuarto, se indica en el epígrafe 1.4.2, *¿Cómo se detectó el problema o cómo ha sucedido?*, que:

(...)

El atacante pudo tener acceso a esos datos personales de los clientes de BCE en atención a la falta de medidas técnicas y organizativas apropiadas previas a la producción de la brecha de datos personales.

En primer término, se ha de significar que, tal y como consta en el hecho privado decimo primero, respecto de las causas que permitieron la brecha de datos personales, en el “Informe de Análisis de Incidente de Seguridad Informe Final”, de fecha 30 de diciembre de 2022, en el epígrafe 3, “Análisis de causas”, que:

(...)

En segundo término, en el hecho probado décimo quinto se recogen las medidas mitigadoras implantadas que ponen de manifiesto la ausencia de medidas técnicas y organizativas apropiadas para impedir la producción de la brecha, destacando, a tales efectos,

(...)

En conclusión y conforme a todo lo indicado, ha quedado constatado que la vulneración del principio de confidencialidad que efectivamente se produjo, pues el atacante ha accedido a múltiples datos personales (...) de la BCE, fue posible en atención a la falta de medidas técnicas y organizativas apropiadas puestas de manifiesto por las vulnerabilidades antedichas.

La documentación obrante en el expediente ofrece indicios evidentes de que BCE, vulneró el artículo 5.1.f) del RGPD, “*Principios relativos al tratamiento*”, al no garantizar debidamente la confidencialidad e integridad de los datos de carácter personal como consecuencia de la quiebra de seguridad producida.

De conformidad con las evidencias de las que se dispone en esta propuesta de resolución del procedimiento sancionador, se considera que los hechos conocidos son constitutivos de una infracción, imputable a BCE, por vulneración del artículo 5.1.f) del RGPD.

V Tipificación por la infracción del artículo 5.1.f) del RGPD

La citada infracción del artículo 5.1.f) del RGPD supone la comisión de las infracciones tipificadas en el artículo 83.5 a) del RGPD, que considera que la infracción de “*los principios básicos para el tratamiento, incluidas las condiciones para el consentimiento a tenor de los artículos 5, 6, 7 y 9*” es sancionable, de acuerdo con el apartado 5 del mencionado artículo 83 del citado Reglamento, “*con multas administrativas de*

20.000.000€ como máximo o, tratándose de una empresa, de una cuantía equivalente al 4% como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía”.

La LOPDGDD en su artículo 71, *Infracciones*, señala que: “Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica”.

Y en su artículo 72, considera a efectos de prescripción, que son: “Infracciones consideradas muy graves:

1. En función de lo que establece el artículo 83.5 del Reglamento (UE) 2016/679 se consideran muy graves y prescribirán a los tres años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

(...)

a) El tratamiento de datos personales vulnerando los principios y garantías establecidos en el artículo 5 del Reglamento (UE) 2016/679.

(...)”

VI Propuesta de sanción por la infracción del artículo 5.1.f) del RGPD

A fin de establecer la multa administrativa que procede imponer han de observarse las previsiones contenidas en los artículos 83.1 y 83.2 del RGPD, que señalan:

“1. Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 5 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias.

2. Las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j). Al decidir la imposición de una multa administrativa y su cuantía en cada caso individual se tendrá debidamente en cuenta:

a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido;

b) la intencionalidad o negligencia en la infracción;

c) cualquier medida tomada por el responsable o encargado del tratamiento para paliar los daños y perjuicios sufridos por los interesados;

d) el grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32;

e) toda infracción anterior cometida por el responsable o el encargado del tratamiento;

- f) el grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción;*
g) las categorías de los datos de carácter personal afectados por la infracción;
h) la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida;
i) cuando las medidas indicadas en el artículo 58, apartado 2, hayan sido ordenadas previamente contra el responsable o el encargado de que se trate en relación con el mismo asunto, el cumplimiento de dichas medidas;
j) la adhesión a códigos de conducta en virtud del artículo 40 o a mecanismos de certificación aprobados con arreglo al artículo 42, y
k) cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción.

En relación con la letra k) del artículo 83.2 del RGPD, la LOPDGDD, en su artículo 76, “Sanciones y medidas correctivas”, establece que:

“2. De acuerdo a lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta:

- a) El carácter continuado de la infracción.*
b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.
c) Los beneficios obtenidos como consecuencia de la comisión de la infracción.
d) La posibilidad de que la conducta del afectado hubiera podido inducir a la comisión de la infracción.
e) La existencia de un proceso de fusión por absorción posterior a la comisión de la infracción, que no puede imputarse a la entidad absorbente.
f) La afectación a los derechos de los menores.
g) Disponer, cuando no fuere obligatorio, de un delegado de protección de datos.
h) El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos, en aquellos supuestos en los que existan controversias entre aquellos y cualquier interesado.”

De acuerdo con los preceptos transcritos, a efectos de fijar el importe de la sanción a imponer en el presente caso por la infracción del artículo 5.1.f) del RGPD, tipificada en el artículo 83.5.a) del RGPD de la que se responsabiliza a BCE, se estiman concurrentes los siguientes factores:

- La naturaleza, gravedad y duración de la infracción; los hechos puestos de manifiesto afectan a un principio básico relativo al tratamiento de los datos de carácter personal, como es el de la confidencialidad e integridad de los mismos, que la norma sanciona con la mayor gravedad al posibilitarse, como consecuencia de la brecha de datos personales, el acceso a los datos de carácter personal por terceros no autorizados con los perjuicios que ello puede conllevar.
- El número de interesados afectados (...), a los que se ha notificado en su totalidad la brecha de datos personales. Los usuarios disponen de acuerdo de

Banca Electrónica, lo que les colocaba en una posición de especial afectación al poder acceder el atacante a la consulta de sus datos económicos.

- En cuanto al nivel de daños y perjuicios causados: debe ser considerado alto pues a los datos de carácter personal (...), hay que añadir datos de tipo económico y financiero puesto que los usuarios que disponían de acuerdo de Banca Electrónica se habría posibilitado el tener acceso a este tipo de datos (...).

Adicionalmente debe señalarse que esta situación posibilita con el acceso a los datos, y con ello se puede producir la materialización del riesgo de suplantación de identidad, entre otros (artículo 83.2.a) del RGPD).

- La intencionalidad o negligencia en la infracción. Se observa falta de diligencia en el cumplimiento de las obligaciones que le impone la normativa de protección de datos, al posibilitar el acceso por ciber-delincuente a los datos de carácter personal vulnerando su confidencialidad; en este sentido puede citarse la SAN de 17/10/2007, que si bien fue dictada antes de la vigencia del RGPD su pronunciamiento es perfectamente extrapolable al supuesto que analizamos. La sentencia, después de aludir a que las entidades en las que el desarrollo de su actividad conlleva un continuo tratamiento de datos de clientes y terceros han de observar un adecuado nivel de diligencia, precisaba que "(...) el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la recurrente es de constante y abundante manejo de datos de carácter personal ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las prevenciones legales al respecto" (artículo 83.2, b) del RGPD).

- La actividad de la entidad presuntamente infractora se encuentra vinculada con el tratamiento de datos de carácter personal tanto de clientes como de terceros. En la actividad de la entidad reclamada es imprescindible el tratamiento de datos de carácter personal por lo que, dado su objeto y volumen de negocio la transcendencia de la conducta objeto de la presente reclamación es innegable (artículo 76.2.b) de la LOPDGDD en relación con el artículo 83.2.k).

A efectos de decidir sobre la proposición de la multa y su cuantía, de conformidad con las evidencias de que se dispone, teniendo en cuenta los criterios del artículo 83.2 del RGPD con respecto a la infracción cometida, vulneración del artículo 5.1.f) del RGPD, se considera proponer una sanción de 6.159 euros.

Se ha reducido la cuantía de la sanción recogida en el Acuerdo de Inicio proporcionalmente al volumen de negocios reconocido en el hecho probado vigésimo primero.

VII Infracción del artículo 32.1 del RGPD

El artículo 32 del RGPD "*Seguridad del tratamiento*", establece que:

“1. Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:

- a) la seudonimización y el cifrado de datos personales;*
- b) la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;*
- c) la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico;*
- d) un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.*

2. Al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, en particular como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.

3. La adhesión a un código de conducta aprobado a tenor del artículo 40 o a un mecanismo de certificación aprobado a tenor del artículo 42 podrá servir de elemento para demostrar el cumplimiento de los requisitos establecidos en el apartado 1 del presente artículo.

4. El responsable y el encargado del tratamiento tomarán medidas para garantizar que cualquier persona que actúe bajo la autoridad del responsable o del encargado y tenga acceso a datos personales solo pueda tratar dichos datos siguiendo instrucciones del responsable, salvo que esté obligada a ello en virtud del Derecho de la Unión o de los Estados miembros”.

Revisadas las alegaciones formuladas por la parte reclamada, y en atención a las mismas, revisada la documentación obrante en el expediente administrativo y la aportada por la parte reclamada, se evidencia que todas las medidas técnicas y organizativas de seguridad cuya ausencia ha quedado probada, posibilitando directamente la brecha de datos personales, sin que se haya producido una conculcación, en el caso concreto, del artículo 32 del RGPD a no haberse acreditado la ausencia de otras medidas técnicas y organizativas de seguridad independientes de la brecha de datos personales.

VIII Infracción del artículo 33 del RGPD

El artículo 33 del RGPD, “Notificación de una violación de la seguridad de los datos personales a la autoridad de control”, establece que,

- “1. En caso de violación de la seguridad de los datos personales, el responsable del tratamiento la notificará a la autoridad de control competente*

de conformidad con el artículo 55 sin dilación indebida y, de ser posible, a más tardar 72 horas después de que haya tenido constancia de ella, a menos que sea improbable que dicha violación de la seguridad constituya un riesgo para los derechos y las libertades de las personas físicas. Si la notificación a la autoridad de control no tiene lugar en el plazo de 72 horas, deberá ir acompañada de indicación de los motivos de la dilación.

2. El encargado del tratamiento notificará sin dilación indebida al responsable del tratamiento las violaciones de la seguridad de los datos personales de las que tenga conocimiento.

3. La notificación contemplada en el apartado 1 deberá, como mínimo:

a) describir la naturaleza de la violación de la seguridad de los datos personales, inclusive, cuando sea posible, las categorías y el número aproximado de interesados afectados, y las categorías y el número aproximado de registros de datos personales afectados;

b) comunicar el nombre y los datos de contacto del delegado de protección de datos o de otro punto de contacto en el que pueda obtenerse más información;

c) describir las posibles consecuencias de la violación de la seguridad de los datos personales;

d) describir las medidas adoptadas o propuestas por el responsable del tratamiento para poner remedio a la violación de la seguridad de los datos personales, incluyendo, si procede, las medidas adoptadas para mitigar los posibles efectos negativos.

4. Si no fuera posible facilitar la información simultáneamente, y en la medida en que no lo sea, la información se facilitará de manera gradual sin dilación indebida.

5. El responsable del tratamiento documentará cualquier violación de la seguridad de los datos personales, incluidos los hechos relacionados con ella, sus efectos y las medidas correctivas adoptadas. Dicha documentación permitirá a la autoridad de control verificar el cumplimiento de lo dispuesto en el presente artículo”.

Con fecha 21/10/2024, se acordó abrir periodo de práctica de pruebas en cuyo punto 3: Se acuerda requerir a BCE, para que aporte la información y/o documentación siguiente:

“Aportar documentación acreditativa de que, en su caso, había encargado o dado instrucciones a su encargado del tratamiento para la notificación a la AEPD de la brecha de datos personales objeto del presente expediente sancionador (art 33 RGPD). Acreditación tanto del encargo como de los

términos de este y de su fecha. El resultado de estas pruebas podrá dar lugar a la realización de otras. En su respuesta deberá indicar la referencia del expediente que consta en el encabezamiento de este documento”.

La parte reclamada ha aportado en respuesta a dicho requerimiento el día 11/5/2024, los siguientes documentos:

Documento número 1: Correo electrónico de fecha 14/12/2024, donde RSI, en su condición de encargado del tratamiento de BCE comunicó a la misma el incidente de seguridad, indicando que estaban preparando un informe al respecto, indicando próximos pasos (notificación a la AEPD y comunicación a los interesados) y solicitando la validación por parte de BCE como responsable del tratamiento.

Analizada la documentación presentada por BCE a que se refiere el Hecho Probado vigésimo, RSI (declaración responsable en documento privado por el máximo responsable de la entidad, sobre la base de solicitud de instrucciones previas por parte del encargado del tratamiento y con la actuación inmediatamente posterior de notificación de la brecha de datos personales a la AEPD) se determina que la parte reclamada ha aportado en respuesta a la práctica de prueba realizada por esta Agencia de fecha 5/11/2024 sobre la acreditación de las instrucciones facilitadas a su encargado del tratamiento, para que procediera a la notificación en su nombre ante la AEPD de la brecha de datos personales objeto de citado procedimiento, conforme al 33 del Reglamento(UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos (en adelante “RGPD”).

Por todo lo cual, se ha de concluir, que, tras el análisis de los hechos investigados, las alegaciones formuladas por la parte reclamada y de las pruebas aportadas en el procedimiento, en atención a las circunstancias concurrentes en el caso concreto, procedería el archivo de la infracción imputada en relación con el artículo 33 del RGPD.

IX Contestación a las alegaciones formuladas respecto del acuerdo de inicio

Con relación a las alegaciones aducidas por BCE al acuerdo de inicio, se procede a dar respuesta a las mismas según el orden en que se exponen en su escrito:

“PRIMERA. SOBRE LA ACUMULACION DE LOS PROCEDIMIENTOS A LAS ENTIDADES DEL GRUPO.”

1. Consideraciones previas

Según BCE: *“La totalidad de los acuerdos de inicio en los expedientes que acaban de referenciarse traen causa, como se ha indicado de la brecha de seguridad analizada por el Acuerdo de Inicio” y, posteriormente afirma que “nos encontramos ante un solo hecho, referido a una única brecha, sufrida con ocasión del desarrollo de la precitada herramienta llevado a cabo por RSI en su condición de encargada del tratamiento y*

que, sin embargo es fragmentada por la AEPD en veintiséis procedimientos diferenciados tramitados contra veintiséis entidades distintas”

En respuesta a estas consideraciones previas cabe señalar que desde la parte reclamada se confunde que los factores que determinaron la vulnerabilidad sean similares en todos los procedimientos iniciados por esta Agencia con que tan sólo se ha producido una sola brecha de datos personales.

Nos encontramos ante unos incidentes que han afectado (...) que son completamente independientes, tanto jurídica como económicamente. Cada una de estas entidades son responsables de los tratamientos de datos de sus clientes de forma diferenciada, y, en consecuencia, existen tantas brechas de seguridad datos personales como responsables de tratamiento de datos han incumplido las obligaciones impuestas por el RGPD. Cada entidad es responsable del tratamiento de sus propios tratamientos y respecto de sus propios clientes.

Todas las entidades a que se refiere la parte reclamada en su escrito de alegaciones habían contratado con RSI, (...).

Sin embargo, que RSI fuera el mismo encargado del tratamiento de todas las Entidades, no determina que pueda hablarse de “*un solo hecho, referido a una única brecha*”.

Cada entidad, como responsable de tratamiento de sus clientes, adoptó autónomamente la decisión de contratar con RSI como encargado de tratamiento, para lo cual cada una de ellas firmó su propio contrato de encargo de tratamiento, en fechas diferenciadas, suscritos por personas distintas con poder suficiente para ello en cada una de las Cajas rurales y con cita a sus distintos delegados de protección de datos, que no son coincidentes.

A mayor abundamiento, tal y como consta también en los hechos probados, tanto el “Informe de Análisis de Incidente de Seguridad”, de fecha 9 de diciembre de 2022, como el “Informe de Análisis de Incidente de Seguridad Informe Final”, de fecha 30 de diciembre de 2022, se ha realizado de manera individualizada para cada una de las cajas rurales, conteniendo sus especificidades propias.

Asimismo, ya producida la brecha de datos personales, las actuaciones de cada una de las entidades no ha sido la misma, actuando cada una de ellas de forma autónoma, tanto respecto de la AEPD (algunas cajas han notificado la brecha de datos personales directamente y otras han encomendado a su encargado de tratamiento que lo llevaran a cabo), como de sus respectivos clientes e independiente de la actuación del resto.

2. De la acumulación de expedientes procedimientos en el ámbito administrativo.

En esta alegación, la parte reclamada considera que: “*El régimen jurídico de la acumulación de procedimientos, como de los procesos, en el ámbito administrativo responde a la idea central de la conectividad, esto es, que la labor de instrucción que debe realizarse se vea favorecida por la apreciación en su conjunto del tema*

planteado y la posibilidad de que la labor de visionado conjunto permita una mejor valoración de los elementos que permiten la aplicación al caso concreto de la norma”.

El artículo 57 de la LPACAP sobre la acumulación de procedimientos establece que: *“El órgano administrativo que inicie o tramite un procedimiento, cualquiera que haya sido la forma de su iniciación, podrá disponer, de oficio o a instancia de parte, su acumulación a otros con los que guarde identidad sustancial o íntima conexión, siempre que sea el mismo órgano quien deba tramitar y resolver el procedimiento. Contra el acuerdo de acumulación no procederá recurso alguno”* (el subrayado corresponde a la AEPD).

En consecuencia, tanto el órgano administrativo que inicie el procedimiento como el que lo tramite pueden disponer su acumulación a otros procedimientos con los que guarde identidad sustancial o íntima conexión, siempre que sea el mismo órgano quien deba tramitar y resolver el procedimiento.

El artículo 57 de la LPACAP confiere a los órganos administrativos una facultad para la mejor gestión de los procedimientos que tramitan, permitiendo su acumulación siempre que guarden, entre ellos, identidad sustancial o íntima conexión. Por tanto, es una posibilidad que tiene la Administración, no estando obligada a proceder a la acumulación en caso de ser solicitada, aunque sí a decidir motivadamente al respecto, como acontece en el presente procedimiento sancionador.

3. De la respuesta a la alegación pretendiendo la acumulación de procedimientos sancionadores.

En esta alegación, la parte reclamada considera que: *“El régimen jurídico de la acumulación de procedimientos, como de los procesos, en el ámbito administrativo responde a la idea central de la conectividad, esto es, que la labor de instrucción que debe realizarse se vea favorecida por la apreciación en su conjunto del tema planteado y la posibilidad de que la labor de visionado conjunto permita una mejor valoración de los elementos que permiten la aplicación al caso concreto de la norma”.*

Cabe responder que las afirmaciones de la parte reclamada no se ven respaldadas por ni por el artículo 57 de la LPACAP, ni por ningún tipo de jurisprudencia o doctrina, en las que se atribuya a la acumulación la finalidad de aportar al órgano decisorio una mejor valoración de los elementos del caso.

La institución de la acumulación es una técnica de simplificación administrativa que permite al órgano que sea competente para tramitar y resolver en un procedimiento principal, la posibilidad de acumular con aquellos otros con los que guarde identidad sustancial o íntima conexión, a efectos de una tramitación y resolución simultánea. El carácter instrumental de la acumulación se determina por el primer límite que establece el artículo 57 de la LPACAP, y es que el órgano *“sea el mismo órgano quien deba tramitar y resolver el procedimiento”*.

Se trata de un acto de trámite, que no puede ser recurrido, ya que así lo establece el propio artículo 57 de la LPACAP, a diferencia de lo establecido en el artículo 112.1 de la propia norma, que sí permite la impugnación de otros actos de trámite cuando estos

“deciden directa o indirectamente el fondo del asunto, determinan la imposibilidad de continuar el procedimiento, producen indefensión o perjuicio irreparable a derechos e intereses legítimos”.

Sin embargo, cuando la LPACAP excluye la posibilidad de recurso es porque es aplicable a la acumulación de procedimientos, como acto de trámite, ninguno de los supuestos del artículo 112.1 de la LPACAP que acabamos de reproducir.

Con estos razonamientos como punto de partida, debe descartarse por completo las alegaciones que la parte reclamada realiza a continuación, a las que también se les dará una respuesta concreta.

A) Existencia de “íntima conexión” o “identidad sustancial”.

La parte reclamada reitera la idea a que se refiere en las consideraciones previas de esta alegación PRIMERA, se produjo *“una única brecha de seguridad de los datos personales, notificada por cada uno de los responsables (directamente o por medio de su encargado del tratamiento RSI”.* Continúa afirmando que *“La conectividad, en el presente supuesto, deriva, por tanto, de que se trata de depurar responsabilidad a veintiséis personas jurídicas, pero por un mismo hecho”*

Como ya se fundamentó en la respuesta a las consideraciones previas de esta alegación PRIMERA, no puede hablarse de una única brecha de datos personales, sino que se han producido tantas brechas de datos personales como entidades, todas ellas independientes entre sí, cada una de ellas responsable de sus propios tratamientos y respecto de sus propios clientes, cuyo sistema ha sido sufrido una quiebra de seguridad.

Para la parte reclamada, existe un único hecho sobre el cual pueden exigirse responsabilidades, el incidente de seguridad en materia informática. Sin embargo, más allá de la propia brecha de datos personales, se ha producido la pérdida de la confidencialidad de los datos personales de los clientes de cada una de las entidades, lo que no puede englobarse como un solo hecho ni como el mismo hecho.

Del mismo modo, debe diferenciarse los hechos relativos a la actuación posterior al conocimiento de la quiebra de seguridad por cada una de las entidades. Algunas entidades notificaron directamente a la AEPD la brecha, mientras que en otras la comunicación se produjo por el encargado de tratamiento por mandato de cada uno de los responsables del tratamiento (de distinta forma y en distintos momentos).

Por último, algunas entidades comunicaron la pérdida de la confidencialidad de sus datos personales a los afectados, cumpliendo con la obligación establecida en el artículo 34 del RGPD y, otras entidades no enviaron ningún tipo de comunicación.

Todos elementos fácticos diversas determinan que no puede hablarse de que, más allá de la misma vulnerabilidad informática, exista una *“íntima conexión”* o *“identidad sustancial”* que justifique la acumulación de los procedimientos.

Respecto a la sentencia del TSJ Castilla-La Mancha que se cita en las alegaciones, cabe realizar las siguientes precisiones:

1) No hay un cumplimiento de una obligación por varias personas conjuntamente, por lo que no concurre el supuesto del art 28.3 Ley 40/15.

Según el artículo 28.3 de la Ley 40/2015, de 1 de octubre: *“Cuando el cumplimiento de una obligación establecida por una norma con rango de Ley corresponda a varias personas conjuntamente, responderán de forma solidaria de las infracciones que, en su caso, se cometan y de las sanciones que se impongan. No obstante, cuando la sanción sea pecuniaria y sea posible se individualizará en la resolución en función del grado de participación de cada responsable”*.

En el presente caso no cabe hablar de la existencia de una responsabilidad solidaria, al no tratarse de una obligación conjunta de BCE con las otras entidades a que se refiere en su escrito de alegación. Los hechos constitutivos de infracción que se le imputan a BCE lo son en su condición de responsable del tratamiento, de conformidad con lo dispuesto en el artículo 4 del RGPD, por lo que el cumplimiento de los principios y obligaciones establecidos en el RGPD y respecto de los tratamientos de datos de sus clientes le corresponden individualmente, no de forma solidaria con las otras entidades, ya que, además, no existe responsabilidad solidaria en el RGPD.

Hay que significar además, que la multa impuesta a cada entidad depende de sus propias circunstancias como el número de clientes afectados o su volumen de negocios.

Tampoco sería aplicable en este caso la figura de corresponsables del tratamiento, regulada en el artículo 26 del RGPD, “cuando dos o más responsables determinen conjuntamente los objetivos y los medios del tratamiento serán considerados corresponsables del tratamiento”. Los objetivos y los medios del tratamiento han sido determinados por BCE de forma independiente a las demás entidades, en su condición de único responsable del tratamiento de los datos personales de los datos de sus clientes.

Por último, tampoco concurre en BCE con relación a las demás entidades, el supuesto que se describe en la sentencia, en el que *“la Administración imputa distintas formas de cooperación o connivencia entre los tres imputados en relación con los mismos hechos”*. Aquí no puede hablarse de ningún tipo de cooperación o connivencia en los hechos, simplemente la responsabilidad de cada una de las Cajas Rurales, y de la relación con el encargado de tratamiento, debido al régimen establecido en el RGPD, según el cual el responsable, en este caso, cada una de las Cajas rurales, tiene el control y la autoridad sobre el tratamiento de datos personales y asume la responsabilidad por el cumplimiento de las obligaciones impuestas por el RGPD. Por su parte, el encargado del tratamiento (RSI), solo debe procesar los datos de acuerdo con las instrucciones recibidas del responsable. No puede determinar los fines y los medios del tratamiento; su función es ejecutar el tratamiento conforme a lo establecido por el responsable.

2) La tramitación por separado de los expedientes no impide que cada entidad pueda presentar sus alegaciones.

En la sentencia del TSJ de Castilla La Mancha a que se refiere BCE, en el Fundamento de Derecho Tercero, se dice que el actor solicitó que se acumulasen todos los procedimientos para poder ejercer adecuadamente el derecho de defensa, *“...pues se referían a los mismos hechos, y se advertía expresamente de que tramitarlos por separado suponía una grave vulneración del derecho de defensa pues se impedía conocerlas alegaciones del resto de implicados y los documentos que en su caso aportasen, todo lo cual podía tener trascendencia para la calificación jurídica de los hechos, la determinación de la existencia o no de infracción y del responsable de la misma.”*

La no acumulación de procedimientos no puede producir ninguno de los perjuicios recogidos en dicho párrafo de la sentencia.—

Respecto a los documentos que sean aportados al procedimiento, aquellos que se refieren al incidente de seguridad, en las actuaciones de investigación se aportaron una serie de documentos por el encargado de tratamiento (recordemos que tanto el “Informe de Análisis de Incidente de Seguridad”, de fecha 9 de diciembre de 2022, como el “Informe de Análisis de Incidente de Seguridad Informe Final”, de fecha 30 de diciembre de 2022, se ha realizado de manera individualizada para cada una de las cajas rurales, conteniendo sus especificidades propias) cuyo acceso a la entidad afectada se ha garantizado mediante el envío, previa solicitud, de la copia del expediente. Aquellos documentos que sean aportados por las entidades responsables del tratamiento, que les afecten individualmente serán tomados a consideración en el procedimiento correspondiente.

3) BCE reitera la necesidad del *“análisis acumulado de los expedientes”*, cuando la sentencia del TSJ de Castilla La Mancha no recoge esta idea. La necesidad de acumulación se basa en otras consideraciones a las expresadas por BCE. Como hemos analizado:

- Se hace referencia al acceso de los documentos obrantes en el expediente que puedan ser aportados por distintos responsables, cuestión que aquí vemos que queda garantizada.
- Se menciona la posibilidad de fijar una responsabilidad solidaria, que, como hemos fundamentado, no se aplica en el régimen establecido en el RGPD. No debemos confundir responsabilidad solidaria del artículo 28 de la LRJSP con la corresponsabilidad del artículo 26 del RGPD, que tampoco aplica en este caso, ya que, como dijimos en ningún caso las demás Cajas Rurales son corresponsables de los tratamientos de los datos de los clientes de las demás entidades.
- No existe ningún tipo de cooperación ni connivencia de las distintas Cajas Rurales en los hechos. Estas figuras deben descartarse por la relación entre las Cajas Rurales, que son entidades independientes y cada una de ellas responsables de los tratamientos de sus clientes, ni, como hemos dicho anteriormente, en cuanto al régimen especial que fija el RGPD de la relación responsable-encargado del tratamiento.

B) Que le corresponda al mismo órgano la tramitación y resolución del procedimiento.

La tramitación de los diversos procedimientos sancionadores corresponde al mismo órgano, tal y como señala BCE, lo que no determina el carácter preceptivo de la decisión de acumular los procedimientos, máxime cuando no concurre ninguna circunstancia que suponga la indefensión de BCE.

4. La conectividad en el ámbito sancionador con las garantías de los artículos 24 y 25.1 de la Constitución española.

En esta alegación BCE señala que el Tribunal Constitucional ha declarado que tanto los principios sustantivos del artículo 25.1 CE como las garantías procedimentales del artículo 24.2 CE son aplicables, con ciertos matices, al ejercicio de la potestad sancionadora.

4.1. Aspectos generales ligados a la instrucción y la funcionalidad esencial de la misma.

A) Vinculación de la instrucción como consecuencia de la unidad fáctica.

BCE cita una sentencia del Tribunal Supremo, en la que se dice que *“la iniciación de un único procedimiento sancionador por la comisión de un mismo hecho infractor, con el objeto de determinar el grado de participación de cada presunto responsable en la comisión de la infracción y procurar que la resolución del expediente sea coherente ...”* Según BCE *“En dicho supuesto, el recurrente alegaba que, al haberse tramitado dos expedientes, cada uno de los responsables era desconocedor de lo que había en el otro que pudiera beneficiarle o perjudicarlo. Es un ejemplo concreto de las dificultades que, en el plano del derecho de defensa, se plantea en los supuestos de tramitación separada”*.

Como ya se ha justificado anteriormente, hay tantas brechas de datos personales como responsables del tratamiento y no podemos hablar de un mismo hecho infractor, sino de una serie de hechos infractores atribuibles a una serie de entidades independientes entre sí, respecto de los tratamientos de los que son responsables, respecto de sus clientes; ni tampoco puede hablarse de *“grado de participación”* entre las diversas entidades, ni en cuanto a la relación responsable-encargado de tratamiento.

Respecto a los documentos que sean aportados al procedimiento, aquellos que se refieren al incidente de seguridad, en las actuaciones de investigación se aportaron una serie de documentos por el encargado de tratamiento, cuyo acceso a todas las entidades afectadas se ha garantizado mediante el envío, previa solicitud, de la copia del expediente. Y todo ello amén de que se aportó por RSI el “Informe de Análisis de Incidente de Seguridad”, de fecha 9 de diciembre de 2022, como el “Informe de Análisis de Incidente de Seguridad Informe Final”, de fecha 30 de diciembre de 2022, de manera individualizada para cada una de las cajas rurales, conteniendo sus especificidades propias.

Aquellos documentos que sean aportados por las entidades responsables del tratamiento, que les afecten individualmente serán tomados a consideración en el procedimiento correspondiente. Y, aquellos otros que pudieran constituir una prueba que tuvieran relevancia sobre los hechos, serán debidamente incorporados a los demás expedientes de oficio, de acuerdo con lo dispuesto en el artículo 75 de la LPACAP, “los actos de instrucción necesarios para la determinación, conocimiento y comprobación de los hechos en virtud de los cuales deba pronunciarse la resolución, se realizarán de oficio”.

B) La conectividad como presupuesto fundamental para el ejercicio del derecho de defensa.

Según BCE, cada uno de los procedimientos sancionadores se vuelven “estancos” y que las pruebas, las alegaciones, las pericias que se realizan en uno no se pueden presentar, de forma contradictoria.

Sin embargo, un párrafo de la sentencia transcrita por BCE es plenamente aplicable para contestar a la presente alegación: *“no se precisa en qué medida se había «perjudicado su defensa», y para rechazarla, del mismo modo que la STS entiende “que es acertada la decisión del Tribunal de instancia, que considera que está justificada la incoación de expedientes sancionadores a cada una de las empresas... debido a la clara diferenciación de las conductas imputadas y no haberse demostrado que se le hubiera producido indefensión real -según se razona en la sentencia impugnada.”*

El Tribunal Constitucional en su sentencia n.º 210/1999, de 29 de noviembre, señala que la indefensión constitucionalmente relevante es la situación en que, tras la infracción de una norma procesal, se impide a alguna de las partes el derecho la defensa eliminando o limitando su potestad, bien de alegar derechos e intereses para que le sean reconocidos, o bien de replicar dialécticamente las posiciones contrarias en el ejercicio del principio de contradicción.

Como característica esencial de la indefensión es que esta deberá tener carácter material y no meramente formal, es decir, no es suficiente con la existencia de un defecto o infracción procesal, sino que debe haberse producido un efectivo y real derecho de defensa (sentencia del Tribunal Constitucional n.º 90/1988, de 13 de mayo).

Pues bien, más allá de una alegación genérica a la eventual indefensión que podría producirse por la no acumulación de los procedimientos, BCE no es capaz de esgrimir un solo defecto o infracción procesal que haya limitado su derecho a la defensa de manera efectiva, cuando las alegaciones presentadas por las Cajas Rurales afectadas por el incidente de seguridad son sustancialmente similares, y han tenido acceso a toda la documentación que les afecta de forma común. En todo caso, el órgano instructor incorporará al procedimiento y pondrá en conocimiento de BCE, aquellos otros documentos que pudieran constituir una prueba que tuvieran relevancia sobre los hechos.

4.2.- La íntima conexión como una exigencia para la individualización de la responsabilidad por los mismos hechos.

Sostiene BCE que, debido a que nos encontramos ante una única brecha de datos personales, al tramitarse procedimientos separados para cada una de las entidades responsables, puede derivar, eventualmente, en la determinación de responsabilidades diversas. La íntima conexión se traduce en el principio de unicidad en la determinación de la concurrencia de los hechos cuando, como alega BCE, se trata de unos únicos hechos que se traducen en una única brecha de datos personales.

Como ya se ha motivado anteriormente, no cabe hablar de una única brecha de datos personales, sino que de tantas como responsables de tratamiento han sufrido el incidente de seguridad respecto a los datos de sus clientes.

No pueden existir diversos grados de responsabilidad entre BCE y las demás entidades. Cada uno de los responsables de tratamiento tendrá un grado de responsabilidad que debe determinarse individualmente respecto al cumplimiento de la normativa de protección de datos, sin que exista ningún tipo de cooperación en la comisión de la infracción entre las distintas Cajas Rurales que pueda determinar distintos grados de responsabilidad entre las entidades, como afirma BCE.

Continúan los razonamientos de BCE diciendo que *“no se puede individualizar la responsabilidad sin que previamente se objetivice el reproche sancionador y éste no puede proyectarse en 26 procedimientos con su propia dinámica, su propia prueba...”*. Se siguen realizando argumentos abstractos tales como objetivar el reproche sancionador, respecto a su propia dinámica y “su propia prueba”, cuando ni si siquiera se han realizado alegaciones poniendo en duda los hechos y las evidencias que constaban en el acuerdo de inicio, ni se ha solicitado el recibimiento a prueba del procedimiento.

El hecho de que se hayan tramitado *“unas únicas actuaciones de investigación”* y que en estas no se haya realizado requerimiento dirigido contra las entidades responsables del tratamiento sino con relación al encargado (RSI), no supone la *“determinación fáctica unitaria”*, como argumenta BCE. Que las actuaciones de inspección se dirigiesen requiriesen información al encargado del tratamiento no determinan que posteriormente deba incoarse un único procedimiento para depurar las responsabilidades administrativas. Cabe recordar que el artículo 53, *“Alcance de la actividad de investigación”*, de la LOPDGDD no impone que aquellas deban realizarse necesariamente con relación al responsable del tratamiento. No existe, por tanto, ninguna obligación de investigar a todos los responsables que realicen el tratamiento en cuestión. Los inspectores pueden obtener las evidencias consultado requiriendo información al encargado del tratamiento si así lo consideran conveniente.

4.3 Afectación al derecho fundamental a la buena administración

Conforme a BCE, la acumulación deviene una obligación en caso de que la ausencia de esta pudiera perjudicar los derechos del administrado, en particular los reconocidos en el artículo 24 de la Constitución, violentándose así el derecho a una buena administración conforme al artículo 41 de la Carta de Derechos Fundamentales de la Unión Europea.

En las alegaciones anteriores se ha motivado las diferencias entre las conductas imputadas a las Cajas Rurales, y de que no se le ha causado ningún tipo de indefensión a BCE en la tramitación del presente procedimiento, habiendo tenido acceso a todos los documentos obrantes en el expediente. De hecho, BCE no ha justificado ningún tipo de indefensión, ni señala ningún hecho concreto por el que se le haya causado indefensión.

Por último, reiterar que no nos encontramos ante unos mismos hechos, sino ante un mismo problema técnico que causó un incidente de seguridad del sistema informático de cada una de las entidades responsables en relación con su tratamiento de datos personales (todas ellas jurídica y económicamente independientes entre sí), que ha producido una serie de brechas de seguridad de datos personales, no una única brecha de datos personales, sino una brecha de datos personales en cada una de las Cajas Rurales, que derivan en la presunta comisión de una serie de infracciones por parte de cada uno de los distintos responsables del tratamiento en relación con sus tratamientos de datos personales y los derechos y libertades de sus clientes.

“SEGUNDA. LA INEXISTENCIA DE CULPABILIDAD DE BCE EN EL PRESENTE CASO”

BCE ha invocado distintos argumentos para justificar la ausencia de culpabilidad de su conducta.

En primer lugar manifiesta que se encuentra al margen de los hechos que se le imputan, toda vez que en el presente caso, el tratamiento es llevado a cabo a través de un encargado del tratamiento; que, a su vez, es el encargado de las entidades contra las que se dirigen los procedimientos; y que la normativa de protección de datos personales no sólo impone las obligaciones relacionadas con el cumplimiento del principio de confidencialidad y la adopción de las necesarias medidas de seguridad al responsable del tratamiento sino, cuando el tratamiento es realizado por cuenta del responsable por parte de un encargado del tratamiento, a éste último.

En este sentido cabe recordar que la figura del encargado del tratamiento obedece a la necesidad de dar respuesta a fenómenos como la externalización de servicios por parte de las empresas y otras entidades, de manera que en aquellos supuestos en que el responsable del tratamiento encomiende a un tercero la prestación de un servicio que requiera que el encargado trate datos personales por su cuenta, el tratamiento o las operaciones del tratamiento se llevan a cabo por el encargado, en nombre y por cuenta del responsable, como si fuera este último quien lo lleva a cabo.

Por lo tanto, la existencia de un encargado del tratamiento depende de una decisión adoptada por el responsable del tratamiento, que podrá decidir realizar por sí mismo

determinadas operaciones de tratamiento o contratar la totalidad o parte del tratamiento con un encargado.

Es decir, que el encargado, para serlo, no ostenta ningún interés propio respecto del resultado del tratamiento objeto de encargo, sin perjuicio de la compensación económica que recibe por el servicio prestado y que es lo que acontece en el presente caso. Los encargados no tienen ningún interés propio, actúan por cuenta y en nombre del responsable, cumpliendo sus órdenes y para las finalidades de éste, y esto es lo que determina que sean encargados desde el principio.

Ello determina que responde el responsable del tratamiento de actuaciones contrarias al RGPD llevadas a cabo por sus encargados del tratamiento, a salvo que estos últimos hubieran actuado como verdaderos responsables del tratamiento, decidiendo sobre los fines y medios del tratamiento, cuestión que no ha acontecido en el presente supuesto.

Así, la STJUE de 5 de diciembre de 2023 dictada en el asunto C-683/21, en cuanto a la cuestión de si puede imponerse una multa administrativa con arreglo al artículo 83 del RGPD a un responsable del tratamiento en relación con las operaciones de tratamiento efectuadas por un encargado, determina que,

“83 Por lo que respecta, en segundo lugar, a la cuestión de si puede imponerse una multa administrativa con arreglo al artículo 83 del RGPD a un responsable del tratamiento en relación con las operaciones de tratamiento efectuadas por un encargado, es preciso recordar que, según la definición que figura en el artículo 4, punto 8, del RGPD, se entiende por encargado del tratamiento «la persona física o jurídica, autoridad pública, servicio u otro organismo que trate datos personales por cuenta del responsable del tratamiento».

84 Dado que, como se ha indicado en el apartado 36 de la presente sentencia, un responsable del tratamiento es responsable no solo por todo tratamiento de datos personales que efectúe él mismo, sino también por los tratamientos realizados por su cuenta, puede imponerse a ese responsable una multa administrativa con arreglo al artículo 83 del RGPD en una situación en la que los datos personales son objeto de un tratamiento ilícito y en la que no es él, sino un encargado al que ha recurrido, quien ha efectuado el tratamiento por cuenta suya.

85 No obstante, la responsabilidad del responsable del tratamiento por el comportamiento de un encargado no puede extenderse a las situaciones en las que el encargado haya tratado datos personales para fines que le sean propios o en las que haya tratado dichos datos de manera incompatible con el marco o las modalidades del tratamiento tal como hayan sido determinados por el responsable del tratamiento o de manera que no pueda considerarse razonablemente que dicho responsable hubiera dado su consentimiento. En efecto, de conformidad con el artículo 28, apartado 10, del RGPD, el encargado del tratamiento debe, en ese supuesto, ser considerado responsable del tratamiento con respecto a dicho tratamiento”. (el subrayado es nuestro)

A lo anterior, hemos de adicionar la reciente SAN de 8 de febrero de 2024, rec. 0002250/2021, respecto de TELEFÓNICA MÓVILES ESPAÑA S.A.U, en la que se determina que,

“Pues bien, la sociedad recurrente es la responsable del tratamiento, pues determina la finalidad y medios de los tratamientos realizados con las finalidades señaladas en su Política de Privacidad: “En Movistar tratamos los datos del cliente o usuario para la prestación del servicio, así como para otras finalidades que el mismo permita o autorice en los términos informados en la presente Política de Privacidad o en las Condiciones específicas de cada Producto o Servicio Movistar contratado”.

Mientras que las compañías ATENTO TELESERVICIOS ESPAÑA, S.A.U., CATHPONE-NET, S.L. y THADER TELECOMUNICACIONES S.L., tienen la consideración de encargados del tratamiento.

Lo expuesto se deriva de los contratos suscritos por la parte actora con las citadas compañías.

....

Pues bien, no ha que quedado acreditado que las citadas empresas, como encargadas del tratamiento de la parte actora, hayan determinado fines y medios del tratamiento, ni hayan utilizado los datos de los clientes de aquella para sus propias finalidades, ni han interactuado frente a los interesados ajenos a la estructura y nombre comercial de la sociedad recurrente, sino que han actuado bajo el nombre de la parte actora para el cumplimiento de los fines de estos, utilizando los sistemas de ésta para realizar las operaciones con los clientes.

Por lo que, no cabe invocar el art. 28.10 del RGPD para una presunta atribución de responsabilidad a los encargados que, además, implique la exoneración del responsable del tratamiento, es decir, de la sociedad aquí recurrente. Por otro lado, conforme a los reseñados contratos, se incluye una cláusula que repercute en ellos las posibles sanciones que la sociedad demandante pudiera sufrir por el incumplimiento de las obligaciones en materia de protección de datos”. (el subrayado es nuestro)

Por otro lado, las Directrices 7/2020 del CEPD sobre los conceptos de «responsable del tratamiento» y «encargado del tratamiento» en el RGPD, versión 2.0 Adoptada el 7 de julio de 2021, determinan que,

“30 Siguiendo la línea del enfoque basado en los hechos, la palabra «determine» significa que el ente que realmente ejerce una influencia decisiva sobre los fines y medios del tratamiento es el responsable. Por lo general, el contrato de tratamiento establece quién es la parte determinante (el responsable del tratamiento) y quién, la parte que sigue las instrucciones (el encargado del tratamiento). Incluso cuando el encargado del tratamiento

ofrezca un servicio que se defina previamente de un modo concreto, deberá presentar al responsable del tratamiento una descripción detallada del servicio, y este deberá adoptar la decisión final sobre la aprobación del modo en que se efectuará el tratamiento y solicitar los cambios que considere necesarios. Además, el encargado del tratamiento no puede modificar, en un momento posterior, los elementos esenciales del tratamiento sin la aprobación del responsable.

...

39. La cuestión es dónde se debe trazar la línea entre las decisiones reservadas al responsable del tratamiento y aquellas que pueden dejarse a la discreción del encargado. Es evidente que las decisiones sobre el fin del tratamiento siempre deben corresponder al responsable.

40. Por lo que respecta a la determinación de los medios, cabe distinguir entre los medios esenciales y los no esenciales. Los medios esenciales se reservan tradicionalmente y de forma inherente al responsable del tratamiento. Estos deben ser determinados obligatoriamente por el responsable del tratamiento, aunque la determinación de los medios no esenciales también puede dejarse en manos de él. Los medios esenciales son medios estrechamente ligados al fin y el alcance del tratamiento, como el tipo de datos personales tratados («¿qué datos se tratarán?»), la duración del tratamiento («¿cuánto tiempo se tratarán?»), las categorías de destinatarios («¿quién tendrá acceso a los datos?») y las categorías de interesados («¿a quién pertenecen los datos personales tratados?»). Además de estar relacionados con el fin del tratamiento, los medios esenciales se encuentran estrechamente vinculados a la cuestión de si el tratamiento es lícito, necesario y proporcionado. Los medios no esenciales están relacionados con aspectos más prácticos del tratamiento en sí, como la elección de un tipo particular de hardware o software o la decisión sobre los pormenores de las medidas de seguridad, que pueden dejarse en manos del encargado del tratamiento.

41. Pese a que las decisiones sobre los medios no esenciales pueden dejarse en manos del encargado del tratamiento, el responsable aún deberá estipular ciertos elementos en el contrato con el encargado: por ejemplo, en relación con el requisito de seguridad, podrá ordenarse la adopción de todas las medidas exigidas en virtud del artículo 32 del RGPD. El contrato también debe establecer que el encargado del tratamiento ayudará al responsable a garantizar el cumplimiento de, por ejemplo, lo dispuesto en el artículo 32. En cualquier caso, el responsable del tratamiento sigue siendo responsable de la aplicación de las medidas técnicas y organizativas apropiadas a fin de garantizar y poder demostrar que el tratamiento es conforme con el Reglamento (artículo 24). Para ello, el responsable debe tener en cuenta la naturaleza, el alcance, el contexto y los fines del tratamiento, además de los riesgos para los derechos y las libertades de las personas físicas. Por este motivo, el responsable del tratamiento debe contar con una información completa sobre los medios utilizados, ya que, así, podrá adoptar una decisión informada al respecto. Para que el responsable pueda demostrar la legalidad del tratamiento, se aconseja documentar, en el contrato u otro instrumento

jurídicamente vinculante entre el responsable y el encargado, al menos las medidas técnicas y organizativas necesarias.

...

74. El RGPD establece obligaciones concretas que vinculan directamente a los encargados del tratamiento, tal como se especifica en la sección 1 del apartado II de las presentes directrices. Es posible exigir responsabilidad o sancionar a un encargado cuando no cumpla con dichas obligaciones o actúe al margen o en contra de las instrucciones legales del responsable.

...

80 En segundo lugar, el tratamiento debe llevarse a cabo por cuenta de un responsable del tratamiento, pero no bajo su autoridad ni control directos. Actuar «por cuenta de» alguien significa servir los intereses de otro y remite al concepto jurídico de «delegación». En el caso de la normativa de protección de datos, el cometido del encargado del tratamiento es aplicar las instrucciones dadas por el responsable del tratamiento, cuando menos en lo relativo a los fines del tratamiento y a los elementos esenciales de los medios. La legitimidad del tratamiento en virtud del artículo 6 y, si procede, del artículo 9 del Reglamento deriva de la actividad del responsable, y el encargado únicamente debe tratar los datos siguiendo las instrucciones dadas por este. Aun así, tal como se ha indicado previamente, las instrucciones del responsable del tratamiento pueden dejar cierto margen de discrecionalidad sobre el modo de servir mejor a los intereses de este, de modo que permitan al encargado elegir los medios técnicos y organizativos más adecuados.

81. Actuar «por cuenta de» alguien también significa que el encargado no puede llevar a cabo el tratamiento para sus propios fines. Tal como se estipula en el artículo 28, apartado 10, el encargado del tratamiento infringirá el RGPD cuando no se ciña a las instrucciones del responsable y comience a determinar sus propios fines y medios del tratamiento. En estos casos, el encargado del tratamiento se considerará responsable en relación con dicho tratamiento y podrá ser sancionado por no haberse adherido a las instrucciones del responsable". (el subrayado es nuestro)

Pues bien, en el caso concreto que se examina, y a la vista de la documentación que obra en el expediente, consta que, para la prestación de los servicios informáticos, BCE tiene suscrito un "Contrato de prestación de servicios" individualizado y específico con RSI.

Asimismo, también tiene suscrito en el marco del anterior el "Acuerdo de modificación de la cláusula de protección de datos de los contratos de prestación de servicios entre BCE y RURAL SERVICIOS INFORMÁTICOS, S.L." relativo a BCE y que fue suscrito el 13/9/2018, por **A.A.A. y B.B.B.**, en representación de BCE (responsable del tratamiento).

En este sentido, en este "Acuerdo de modificación de la cláusula de protección de datos de los contratos de prestación de servicios entre BCE y RURAL SERVICIOS

INFORMÁTICOS, S.L.”, se identifica a la BCE como responsable del tratamiento y a RSI como encargado del tratamiento.

Además, en este “Acuerdo de modificación de la cláusula de protección de datos de los contratos de prestación de servicios entre BCE y RURAL SERVICIOS INFORMÁTICOS, S.L.” se definen los tratamientos que se podrían llevar a cabo por RSI por cuenta de la BCE, la tipología de la información a tratar y las categorías de los interesados cuyos datos podrían ser tratados.

Asimismo, se determina que las medidas de seguridad que se deben aplicar por parte de RSI para garantizar un nivel de seguridad adecuado al riesgo conforme en lo establecido en el artículo 32 del RGPD son las establecidas en el anexo B del “Acuerdo de modificación de la cláusula de protección de datos de los contratos de prestación de servicios entre BCE y RURAL SERVICIOS INFORMÁTICOS, S.L.”

También hemos de destacar que se recoge en el apartado 6 del Acuerdo sobre la “Responsabilidad” que,

“Si el Encargado, o en su caso, los contratistas, infringen este Acuerdo o la normativa vigente al determinar los fines y medios del tratamiento, serán considerados responsables del tratamiento con respecto a dicho tratamiento.

En caso de que una autoridad de control sancionase al Responsable del Tratamiento como consecuencia directa, de que el Encargado del Tratamiento no haya cumplido las estipulaciones de este Acuerdo, el Encargado indemnizará al Responsable del Tratamiento en lo estipulado en la cláusula de responsabilidad del contrato marco vigente entre las partes” (el subrayado es nuestro).

Ello implica, a sensu contrario y conforme determina la normativa de protección de datos, las sentencias precitadas y las Directrices 7/2020, que el responsable del tratamiento responde de las actuaciones llevadas a cabo por su encargado de tratamiento a salvo que este determine fines y medios, resultando que esta última cuestión no ha quedado acreditada en el procedimiento tramitado.

Por tanto, de acuerdo con lo expuesto, BCE es la responsable del tratamiento que se realiza, es quien ha decidido encomendar a un encargado del tratamiento que lo realice en su nombre y por su cuenta, es la entidad que tiene la verdadera capacidad para ejercer el control sobre el tratamiento de datos personales, quien determina qué datos personales serán tratados en su nombre y por su cuenta, el por qué y el cómo deberán tratarse estos, pues define la finalidad del tratamiento de datos personales que su actividad comprende y elige los medios que considera oportuno.

Y conforme a todo lo antedicho y para el caso concreto BCE es responsable de la infracción del RGPD aun cuando se haya producido la incidencia en el seno de su encargado del tratamiento.

En este sentido, en el propio Acuerdo de Inicio se indica en el apartado 4 relativo a las Obligaciones del responsable del Tratamiento que:

“Corresponde al responsable del tratamiento:

- a) *Entregar al Encargado del Tratamiento los datos necesarios para la prestación del servicio*
- b) *En caso de que legalmente resulte exigible, realizar una evaluación de impacto en la protección de datos personales de las operaciones de tratamiento a realizar por el Encargado del Tratamiento.*
- c) *Realizar las consultas previas que corresponda.*
- d) *Velar, de forma previa y durante todo el tratamiento, por el cumplimiento de RGPD, por parte del Encargado del Tratamiento.*
- e) *Supervisar el tratamiento, incluida la realización de inspecciones y auditorías*. (el subrayado es nuestro)

Esto se relaciona directamente con el principio de responsabilidad proactiva del responsable del tratamiento previsto en el artículo 5.2 del RGPD que establece que «el responsable del tratamiento será responsable del cumplimiento de lo dispuesto en el apartado 1 y capaz de demostrarlo (“responsabilidad proactiva”)». Esto significa que el responsable deberá garantizar la aplicación efectiva de los principios del tratamiento tanto en el momento de determinar los medios del tratamiento como durante el tratamiento en sí, bien lleve a cabo el tratamiento de datos personales directamente o encargue a un encargado del tratamiento que lo realice por su cuenta (a efectos de la normativa de protección de datos es lo mismo), a través de la articulación de una serie de medidas técnicas y organizativa de todo tipo, las cuales deberán ser objeto de revisión y actualización periódica. Ello implica que el citado responsable es el que asume su propia responsabilidad dirigiendo, revisando y coordinando el tratamiento, incluyendo la del personal y la del encargado del tratamiento que le presta servicios.

El Dictamen 3/2010, del Grupo de Trabajo del artículo 29 (GT29) -WP 173- emitido durante la vigencia de la derogada Directiva 95/46/CEE, cuyas previsiones son aplicables en la actualidad, afirma que la “esencia” de la responsabilidad proactiva es la obligación del responsable del tratamiento de aplicar medidas que, en circunstancias normales, garanticen que en el contexto de las operaciones de tratamiento se cumplen las normas en materia de protección de datos y en tener disponibles documentos que demuestren a los interesados y a las Autoridades de control qué medidas se han adoptado para alcanzar el cumplimiento de las normas en materia de protección de datos.

Se tiene en cuenta a estos efectos lo señalado en el considerando 74 del RGPD,

“Debe quedar establecida la responsabilidad del responsable del tratamiento por cualquier tratamiento de datos personales realizado por él mismo o por su cuenta. En particular, el responsable debe estar obligado a aplicar medidas oportunas y eficaces y ha de poder demostrar la conformidad de las actividades de tratamiento con el presente Reglamento, incluida la eficacia de las medidas. Dichas medidas deben tener en cuenta la naturaleza, el ámbito, el contexto y los fines del tratamiento, así como el riesgo para los derechos y libertades de las personas físicas.” (el subrayado es nuestro)

Completando lo anterior y en desarrollo del artículo 5.2 del RGPD se ha de citar el artículo 24 y 25 del mismo texto legal, indicando este último respecto a la “Protección de datos desde el diseño y por defecto” que el derecho fundamental a la protección de

los datos personales es mucho más que mera tecnología, pues su enfoque es en los riesgos en los derechos y libertades de los interesados derivados del tratamiento de los datos personales,

“1. Teniendo en cuenta el estado de la técnica, el coste de la aplicación y la naturaleza, ámbito, contexto y fines del tratamiento, así como los riesgos de diversa probabilidad y gravedad que entraña el tratamiento para los derechos y libertades de las personas físicas, el responsable del tratamiento aplicará, tanto en el momento de determinar los medios de tratamiento como en el momento del propio tratamiento, medidas técnicas y organizativas apropiadas, como la seudonimización, concebidas para aplicar de forma efectiva los principios de protección de datos, como la minimización de datos, e integrar las garantías necesarias en el tratamiento, a fin de cumplir los requisitos del presente Reglamento y proteger los derechos de los interesados.

2. El responsable del tratamiento aplicará las medidas técnicas y organizativas apropiadas con miras a garantizar que, por defecto, solo sean objeto de tratamiento los datos personales que sean necesarios para cada uno de los fines específicos del tratamiento...”

BCE parece sostener que la responsabilidad la tiene el encargado del tratamiento con el que suscribió un contrato y en cuya virtud se obligaba a la implementación de las medidas de seguridad adecuadas al riesgo, sin embargo, conviene recordar que la brecha de datos personales se produjo como consecuencia de la decisión de BCE (...), suscribiendo al efecto el correspondiente encargo de tratamiento con RSI donde la BCE dispuso las condiciones oportunas.

Y ello amén de lo motivado por esta Agencia en párrafos precedentes sobre que BCE ha determinado fines y medios del tratamiento, que es responsable del tratamiento, que es responsable de la brecha de datos personales en este caso por las actuaciones de tratamiento efectuadas por su encargado de tratamiento por cuenta de aquella y que está sujeta a las obligaciones del RGPD, especialmente en cuanto a la responsabilidad proactiva.

Ello es responsabilidad de BCE por cuanto, es la responsable del tratamiento y es quien tiene la obligación de integrar y desplegar la protección de datos dentro de todo lo que constituya su organización, en todos sus ámbitos de actuación, ya afecten a sus empleados o a sus encargados del tratamiento. Se debe de tener muy presente que en última instancia la finalidad determinante es la de garantizar la protección del interesado, pues el foco está los riesgos en los derechos y libertades de los interesados derivados del tratamiento de datos personales que realiza el responsable del tratamiento.

Por consiguiente, el responsable del tratamiento debe llevar a cabo un análisis de los riesgos de los derechos y libertades de las personas físicas en los tratamientos de datos, implantando las medidas técnicas y organizativas apropiadas para aplicar los principios de protección de datos e integrar las garantías necesarias en el tratamiento, a fin de cumplir los requisitos del RGPD, debiendo poder demostrar que el tratamiento es conforme con lo previsto en la citada norma. Y a la luz del principio de

responsabilidad proactiva (art 5.2 RGPD), el responsable del tratamiento debe poder demostrar que ha tomado en cuenta todos los elementos previstos en el RGPD.

Por tanto, todo ello no hace sino reflejar una falta de diligencia por parte de la entidad investigada a la hora de garantizar una seguridad adecuada al riesgo de los tratamientos de datos que lleva a cabo. En este sentido, no debe olvidarse que en la base de datos afectada se encuentran almacenados datos personales de miles de clientes, lo cual supone un tratamiento a gran escala, a los que, a su vez, se acceden desde aplicaciones web, es decir, desde internet, con una superficie de exposición muy importante, como mayores riesgos para los interesados, lo que exige medidas técnicas y organizativas apropiadas de todo tipo, incluidas las de seguridad, y dirigidas especialmente a garantizar que no se produzca un acceso ilegítimo a dichos datos personales.

Tal y como se ha venido demostrando y argumentando a lo largo del presente procedimiento sancionador, se considera que no había implantadas unas medidas, en este caso, de seguridad apropiadas para garantizar la seguridad de los datos personales de los clientes, lo que determinó en este supuesto un acceso ilegítimo a los datos personales de los clientes de la BCE. Por tanto, no se está exigiendo una responsabilidad como consecuencia exclusiva de un resultado provocado por un ciberataque.

Es mucho más, es una falta de incumplimiento de las obligaciones impuestas por el RGPD. Por tanto, se insiste, en que el responsable del tratamiento debe establecer, en su relación con el encargado del tratamiento, modalidades claras para dicha asistencia y dar instrucciones precisas al encargado del tratamiento sobre cómo cumplirlas de forma adecuada y documentarlo previamente a través de un contrato o bien en otro acuerdo (vinculante) y también posteriormente durante la vigencia del mismo y comprobar en todo momento del desarrollo del contrato su cumplimiento en la forma establecida en el mismo.

Basta con traer a colación el contenido de la STS 1562/2020, de 15 de junio de 2020, rec. 601/2019, que señala lo siguiente:

“En tal sentido, ya la Sentencia del Tribunal Supremo de 5 de junio de 2004, que confirma, en casación para Unificación de Doctrina, la de esta AN de 16 de octubre de 2003, haciéndose eco de lo argumentado por esta Sala refiere la diferenciación de dos responsables en función de que el poder decisión vaya dirigido al fichero o al propio tratamiento de datos. Así, el responsable del fichero es quien decide la creación del fichero y su aplicación, y también su finalidad, contenido y uso, es decir, quien tiene capacidad de decisión sobre la totalidad de los datos registrados en dicho fichero. El responsable del tratamiento, sin embargo, es el sujeto al que cabe imputar las decisiones sobre las concretas actividades de un determinado tratamiento de datos, esto es, sobre una aplicación específica. Se trataría de todos aquellos supuestos en los que el poder de decisión debe diferenciarse de la realización material de la actividad que integra el tratamiento. Con ello, como asimismo argumenta la STS de 26 de abril de 2005 (casación para unificación de doctrina 217/2004), el legislador español pretende adaptarse a las exigencias de la Directiva 95/46/CE, que tiene como objetivo dar respuesta legal al fenómeno, que cada

vez es más frecuente, de la llamada externalización de los servicios informáticos, donde actúan múltiples operadores, muchos de ellos insolventes, creados con el objetivo de buscar la impunidad o irresponsabilidad de los que le siguen en los eslabones siguientes de la cadena. En la actualidad, el nuevo Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales (por el que se deroga la Directiva 95/46/CE, y de aplicación directa a partir del 25 de mayo de 2018) distingue asimismo entre las figuras del responsable y del encargado del tratamiento. La primera se define en el apartado 7) del artículo 4 como "persona física o jurídica (...) que determine los fines y medios del tratamiento". Y el encargado de tratamiento en el apartado 8) del mismo artículo 4 como aquel que "trate datos personales por cuenta del responsable del tratamiento".

Ello en relación con los Artículos 24 y 28 del mismo Reglamento Europeo de Protección de Datos. Responsable y encargado del tratamiento de datos que, sin lugar a duda, resultan asimismo responsables de las infracciones en materia de protección de datos, en tal nuevo marco normativo, de conformidad con lo previsto en el artículo 82.2 del repetido Reglamento (UE) 2016/679 a cuyo tenor: Cualquier responsable que participe en la operación de tratamiento responderá de los daños y perjuicios causados en caso de que dicha operación no cumpla lo dispuesto por el presente Reglamento. Un encargado únicamente responderá de los daños y perjuicios causados por el tratamiento cuando no haya cumplido con las obligaciones del presente Reglamento dirigidas específicamente a los encargados o haya actuado al margen o en contra de las instrucciones legales del responsable. Se desprende de todo lo anterior que la concurrencia, en el presente supuesto, de un encargado del tratamiento ZZZZ en absoluto exime de responsabilidad a la entidad XXXX ahora recurrente, y ello a pesar de la contundencia de las cláusulas que figuran en el contrato y anexo al mismo firmados por ambas compañías (hechos probados 9 y 10) en cuanto los datos personales tratados lo fueron con la finalidad de llevar a cabo una campaña publicitaria respecto de seguros de coche y moto que comercializaba la (XXXX), en definitiva en beneficio de dicha XXXX, siendo tal entidad actora la que, en último término, determina los fines y medios del repetido tratamiento de datos, por lo que la misma no puede ser exonerada de responsabilidad".

Continúa la STS, en relación con la posible exoneración de responsabilidad alegada en cuanto a lo suscrito en el contrato de «encargado del tratamiento», lo siguiente:

"La conducta sancionada de obstaculización o impedimento por XXXX del ejercicio por su cliente del derecho de oposición al tratamiento de sus datos, se manifiesta en que dicha sociedad no adoptó ninguna clase de medida o de cautela para evitar el envío de publicidad a las direcciones de correo electrónico de su cliente por parte de aquellas empresas a las que encomendó la realización de las campañas publicitarias.

La adopción de las medidas o cautelas necesarias para asegurar la efectividad del derecho de oposición al tratamiento de sus datos por parte de XXXX, como responsable del fichero, subsisten aunque las campañas publicitarias no se

realicen a partir de los datos de sus propios ficheros, sino con bases de datos de otras compañías contratadas por XXXX, y en este caso quedó acreditado que la recurrente no comunicó a las empresas con las que contrató la realización de servicios de publicidad la oposición del denunciante a recibir publicidad de la Mutua, ni en definitiva adoptó previsión alguna para asegurar la exclusión de su cliente de los envíos publicitarios contratados con terceras entidades.”

En lo que respecta a la aplicación del principio de culpabilidad en el ámbito del derecho sancionador regulado por el RGPD, la entidad investigada trae a colación la doctrina sentada por la STJUE, de 5 de diciembre de 2023 (asunto C-807/21, *Deutsche Wohnen SE y Staatsanwaltschaft Berlin*).

Pues bien, cabe preguntarse entonces cuáles son los parámetros de la diligencia debida que la entidad investigada debía haber observado en relación con la conducta examinada. La respuesta es que la diligencia que debió observar es la que era precisa para cumplir las obligaciones que le imponen los artículos 5.2, 24 y 25 del RGPD, a la luz de la doctrina de la Audiencia Nacional y la jurisprudencia del Tribunal Supremo.

Es plenamente aplicable al caso la SAN de 17 de octubre de 2007 (rec. 63/2006), que, después de referirse a que las entidades en las que el desarrollo de su actividad conlleva un continuo tratamiento de datos de clientes y terceros han de observar un adecuado nivel de diligencia, dice:

“[...] el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la recurrente es de constante y abundante manejo de datos de carácter personal ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las prevenciones legales al respecto”.

A mayor abundamiento, la Audiencia Nacional en materia de protección de datos de carácter personal, ha declarado que *“basta la simple negligencia o incumplimiento de los deberes que la Ley impone a las personas responsables de ficheros o del tratamiento de datos de extremar la diligencia...”* (Sentencia de la Audiencia Nacional de 29 de junio de 2001).

En cuanto a la alegación formulada que la brecha de datos personales se produjo en el marco de los tratamientos de datos de los que RSI era encargada del tratamiento, hasta el punto de llevar a cabo las actuaciones de investigación de forma exclusiva con dicha entidad, procede señalar que precisamente las actuaciones previas de investigación se realizan para esclarecer los hechos y las circunstancias de lo acontecido, recabando más información al objeto de poder determinar o no la existencia de una posible infracción de la normativa en materia de protección de datos. En este sentido, el inicio de investigaciones previas y su realización, potestad de la AEPD, no prejuzga nada, sino que permite determinar los hechos acaecidos y recabar la información necesaria allá donde se encuentre para determinar si hay indicios o no de infracción. Incluso tras dicha investigación, puede ser que se archiven las

actuaciones por entender, a la vista de la información recabada, que no existen indicios de infracción. Lo cual, en el presente caso, no ha sucedido.

En consecuencia, las alegaciones deben ser desestimadas toda vez que la entidad investigada ha infringido las obligaciones impuestas en el RGPD en calidad de responsable de los tratamientos llevados a cabo en su nombre y por su cuenta, en relación con las responsabilidades que exige a todo responsable del tratamiento el artículo 24 del RGPD. En consecuencia, las alegaciones deben ser desestimadas, significándose que las argumentaciones presentadas no desvirtúan el contenido esencial de la infracción que se declara cometida ni suponen causa de justificación o exculpación suficiente.

“TERCERA. SOBRE LA AFECTACIÓN A LOS PRINCIPIOS DEL DERECHO SANCIONADOR DERIVADOS DE LA INTERPRETACIÓN EFECTUADA POR LA AEPD”

Considera BCE que no ha cometido infracción alguna de la normativa de Protección de Datos y menos aún la infracción simultánea de los artículos 5.1 f) y 32 del RGPD al concurrir la triple identidad de sujeto, hecho y bien jurídico protegido, no cabe duda de que en este caso debería aplicarse el principio *non bis in idem*, con la imposición sólo de la sanción por el artículo 5.1.f) por la ser más grave una sola de las dos infracciones imputadas.

Y para el caso de que la AEPD aprecie la vulneración, que subsidiariamente aprecie un concurso medial al encontrarse una de las infracciones subsumida y embebida en la otra, según lo previsto en el artículo 29.5 de la LRJSP, *“Cuando de la comisión de una infracción derive necesariamente la comisión de otra u otras, se deberá imponer únicamente la sanción correspondiente a la infracción más grave cometida”*.

“1. Vulneración del principio non bis in idem en la aplicación de los artículos 5.1 f) y 32 del RGPD”

En este sentido, y en relación con esta alegación formulada por la BCE frente al acuerdo de inicio, se ha de indicar que habiendo sido propuesto el archivo de la infracción inicialmente imputada del art. 32 del RGPD, ya no resulta preciso dar contestación a estas alegaciones, puesto que ya no concurre la imputación de la infracción del artículo 5.1.f) del RGPD con la imputación de la infracción del artículo 32 del RGPD.

“CUARTA. SOBRE LA PRETENDIDA VULNERACIÓN DEL ARTÍCULO 32.1 DEL RGPD”

BCE ha manifestado que la AEPD da por *“evidenciada”* la supuesta vulneración del artículo 32 del RGPD, es decir, considera evidente la supuesta insuficiencia de las medidas de seguridad adoptadas como consecuencia del hecho de haberse producido la brecha datos personales y haciendo exclusiva referencia al informe sobre la brecha

producida obrante en el expediente administrativo, obviándose en el acuerdo de inicio todas las medidas adoptadas así como la auditoría realizada y que se realiza una interpretación errónea de lo acaecido en los sistemas de RSI, (...).

Pues bien, como se ha indicado, revisadas las alegaciones formuladas por la parte reclamada, y en atención a las mismas, revisada la documentación obrante en el expediente administrativo y la aportada por la parte reclamada, se evidencia que todas las medidas técnicas y organizativas de seguridad cuya ausencia ha quedado probada, han tenido una incidencia directa en la brecha de datos personales, sin que se haya producido una conculcación, en el caso concreto, del artículo 32 del RGPD a no haberse acreditado la ausencia de otras medidas técnicas y organizativas de seguridad independientes de la brecha de datos personales.

Respecto de la suficiencia de las medidas de seguridad, en relación con el incumplimiento del artículo 5.1.f) del RGPD, nos remitimos a lo ya indicado en el fundamento de derecho IV de esta propuesta de resolución en la que se explica y motiva pormenorizadamente por qué no eran ni suficientes ni apropiadas.

A mayor abundamiento, indicaremos que, es cierto que consta, que, tanto con anterioridad como con posterioridad al incidente de seguridad, la entidad investigada realizó auditorías y revisiones por terceros especialistas orientadas a detectar vulnerabilidades en relación, exclusivamente, con la seguridad de los sistemas de información; pero también lo es que a pesar de la existencia de dichas investigaciones, controles y comprobaciones no fueron capaces de localizar y revelar las vulnerabilidades existentes, tal y como consta en los hechos probados.

Por otro lado, BCE alega que RSI cuenta con diversas certificaciones en materia de seguridad, referenciadas en el hecho probado tercero de esta propuesta de resolución.

El artículo 28 del RGPD, Encargado del tratamiento, en su apartado 5, establece que:

“5. La adhesión del encargado del tratamiento a un código de conducta aprobado a tenor del artículo 40 o a un mecanismo de certificación aprobado a tenor del artículo 42 podrá utilizarse como elemento para demostrar la existencia de las garantías suficientes a que se refieren los apartados 1 y 4 del presente artículo”.

En este sentido, para demostrar que los encargados ofrecen la idoneidad y las garantías exigidas por el RGPD, la adhesión a un mecanismo de certificación puede ser utilizado como un elemento más para hacer constar la existencia de garantías suficientes para aplicar medidas técnicas y organizativas apropiadas para proteger los datos personales.

Y ello porque amén de que un encargado del tratamiento se haya certificado en protección de datos, este certificado no prueba de manera absoluta que las garantías suficientes en relación, en este caso, con la previsión del art. 28.1 del RGPD, hayan sido implementadas y estén actuando de manera efectiva durante todo el ciclo del tratamiento y el tiempo en que este último se esté produciendo.

En materia de protección de datos, este tipo de instrumentos son mecanismos de cumplimiento voluntario en los que se establecen reglas específicas con la finalidad de contribuir a la correcta aplicación del RGPD y la LOPDPGDD.

Según el RGPD el responsable del tratamiento deberá adoptar medidas apropiadas, incluida la elección de encargados, de forma que garantice y esté en condiciones de demostrar que el tratamiento se realiza conforme el RGPD (principio de responsabilidad activa).

Es cierto que constan citadas en el contrato de encargo de tratamiento las certificaciones con las que parece que cuenta el encargado del tratamiento RSI; sin embargo, fijémonos que todas las certificaciones que están recogidas en el hecho probado tercero, no son certificados de los previstos ni en el artículo 28 ni en el artículo 42 del RGPD, no son certificaciones en protección de datos, sino que son certificaciones de seguridad de la información o en relación con otras obligaciones que tienen que cumplirse por el responsable o el encargado del tratamiento en base a otra normativa distinta de la de protección de datos.

Así, en el “Acuerdo de modificación de la cláusula de protección de datos de los contratos de prestación de servicios”, suscrito entre BCE y RSI, en su “Anexo B-Medidas de Seguridad al Acuerdo de modificación de la cláusula de protección de datos de los contratos de prestación de servicios”, en el que se indica que RSI cuenta con las siguientes certificaciones:

(...)

Además de que su cita en el contrato de encargo no va acompañada de la certificación misma -a los efectos de verificar que efectivamente ha sido certificada y para ver exactamente en qué está certificada, en qué momento fue certificada y si en el momento de la brecha de datos personales la certificación seguía vigente (puesto que las certificaciones tienen una vigencia)-, dicha certificación no es de protección de datos.

En este sentido, el informe del Gabinete Jurídico 170/2018 de la AEPD establece la diferencia entre la seguridad de la información y la protección de datos de carácter personal. Así, se indica que,

“Con carácter previo a analizar la concreta cuestión que planteada en la consulta este Gabinete Jurídico estima conveniente hacer una referencia previa (...).

Por lo que se refiere a la seguridad de la información, la misma comprende el conjunto de técnicas y medidas orientadas a garantizar la confidencialidad, la integridad y la disponibilidad de la información y los datos importantes para cualquier organización, independientemente del formato que tengan. (...)

Por el contrario, la protección de datos de carácter personal de las personas físicas se configura como un auténtico derecho fundamental que encuentra su fundamento en el artículo 18.4 de la Constitución Española, conforme al cual

“la ley limitará el uso de la informática para garantizar el honor y la intimidad personal y familiar de los ciudadanos y el pleno ejercicio de sus derechos”. Así lo ha reconocido nuestro Tribunal Constitucional, destacando en la Sentencia 94/1998, de 4 de mayo que el citado artículo 18.4 “no sólo entraña un específico instrumento de protección de los derechos del ciudadano frente al uso torticero de la tecnología informática, sino que consagra un derecho fundamental autónomo a controlar el flujo de informaciones que conciernen a cada persona -a la «privacidad» según el neologismo que reza en la Exposición de Motivos de la LORTAD- pertenezcan o no al ámbito más estricto de la intimidad, para así preservar el pleno ejercicio de sus derechos”.

Así se recoge en el Preámbulo del Proyecto de Ley Orgánica de Protección de Datos Personales y Garantía de los Derechos Digitales, que por su claridad se transcribe a continuación:

“La protección de las personas físicas en relación con el tratamiento de datos personales es un derecho fundamental protegido por el artículo 18.4 de la Constitución española. De esta manera, nuestra Constitución fue pionera en el reconocimiento del derecho fundamental a la protección de datos personales cuando dispuso que «la ley limitará el uso de la informática para garantizar el honor y la intimidad personal y familiar de los ciudadanos y el pleno ejercicio de sus derechos». Se hacía así eco de los trabajos desarrollados desde finales de la década de 1960 en el Consejo de Europa y de las pocas disposiciones legales adoptadas en países de nuestro entorno.

El Tribunal Constitucional señaló en su Sentencia 94/1998, de 4 de mayo, que nos encontramos ante un derecho fundamental a la protección de datos por el que se garantiza a la persona el control sobre sus datos, cualesquiera datos personales, y sobre su uso y destino, para evitar el tráfico ilícito de los mismos o lesivo para la dignidad y los derechos de los afectados; de esta forma, el derecho a la protección de datos se configura como una facultad del ciudadano para oponerse a que determinados datos personales sean usados para fines distintos a aquél que justificó su obtención. Por su parte, en la Sentencia 292/2000, de 30 de noviembre, lo considera como un derecho autónomo e independiente que consiste en un poder de disposición y de control sobre los datos personales que faculta a la persona para decidir cuáles de esos datos proporcionar a un tercero, sea el Estado o un particular, o cuáles puede este tercero recabar, y que también permite al individuo saber quién posee esos datos personales y para qué, pudiendo oponerse a esa posesión o uso.

A nivel legislativo, la concreción y desarrollo del derecho fundamental de protección de las personas físicas en relación con el tratamiento de datos personales tuvo lugar en sus orígenes mediante la aprobación de la Ley Orgánica 5/1992, de 29 de octubre, reguladora del tratamiento automatizado de datos personales, conocida como LORTAD. La Ley Orgánica 5/1992 fue reemplazada por la Ley Orgánica 15/1999, de 5 de diciembre, de protección de datos personales, a fin de trasponer a nuestro derecho a la Directiva 95/46/CE del Parlamento Europeo y del Consejo, de 24 de octubre de 1995, relativa a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos. Esta ley orgánica supuso un

segundo hito en la evolución de la regulación del derecho fundamental a la protección de datos en España y se complementó con una cada vez más abundante jurisprudencia procedente de los órganos de la jurisdicción contencioso-administrativa.

Por otra parte, también se recoge en el artículo 8 de la Carta de los Derechos Fundamentales de la Unión Europea y en el artículo 16.1 del Tratado de Funcionamiento de la Unión Europea. Anteriormente, a nivel europeo, se había adoptado la Directiva 95/46/CE citada, cuyo objeto era procurar que la garantía del derecho a la protección de datos personales no supusiese un obstáculo a la libre circulación de los datos en el seno de la Unión, estableciendo así un espacio común de garantía del derecho que, al propio tiempo, asegurase que en caso de transferencia internacional de los datos, su tratamiento en el país de destino estuviese protegido por salvaguardas adecuadas a las previstas en la propia directiva”.

Y en este mismo sentido se pronuncia el Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de sus datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento general de protección de datos, RGPD), que tiene por objeto “proteger los derechos y libertades fundamentales de las personas físicas y, en particular, su derecho a la protección de los datos personales” (artículo 1.2.), destacando en su Considerando 1 que “la protección de las personas físicas en relación con el tratamiento de datos personales es un derecho fundamental” y en su Considerando 10 que “para garantizar un nivel uniforme y elevado de protección de las personas físicas y eliminar los obstáculos a la circulación de datos personales dentro de la Unión, el nivel de protección de los derechos y libertades de las personas físicas por lo que se refiere al tratamiento de dichos datos deber ser equivalente en todos los Estados miembros. Debe garantizarse en toda la Unión que la aplicación de las normas de protección de los derechos y libertades fundamentales de las personas físicas en relación con el tratamiento de datos de carácter personal sea coherente y homogéneo”.

Consecuentemente, el derecho a la protección de datos de carácter personal de las personas físicas es un derecho fundamental y, por tanto, situado en el máximo nivel de protección jurídica, que actualmente se encuentra regulado directamente por la normativa comunitaria, estableciendo el citado RGPD un conjunto de principios, derechos, obligaciones y una estructura organizativa tendentes a garantizar dicho derecho fundamental. Dentro de los mismos, la seguridad de la información aparece como una obligación más de los responsables y encargados del tratamiento quienes deberán aplicar las medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que incluirán, entre otros factores “la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento” y “la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico” (artículo 32.2. b) y c) del RGPD).

Por lo tanto, no cabe duda de que la garantía de la seguridad de los datos personales adquiere una especial trascendencia en cuanto a su protección, pero sin que ésta se limite exclusivamente al ámbito de la seguridad de dicha información, en cuanto que la protección de datos personales tiene un ámbito mucho más extenso que abarca, como decíamos, a un conjunto de principios, derechos y obligaciones mucho más amplio. (el subrayado es nuestro)

Esta cuestión es sustancial puesto que la certificación citada en el contrato de encargo no sirve como un elemento para “demostrar la existencia de las garantías suficientes a que se refieren los apartados 1 y 4” del artículo 28 del RGPD, al no versar sobre protección de datos. La diferencia de enfoque entre la mera seguridad de la información y la protección de datos es importantísima, ya que mientras que el enfoque de la primera se centra exclusivamente en la seguridad de la información, el enfoque de riesgos propio del RGPD (mucho más amplio pues se centra en los riesgos en los derechos y libertades de los interesados derivados del tratamiento de datos personales) se enfoca en las personas físicas, siendo la seguridad una obligación más dentro de las del RGPD para conseguir la protección de las personas físicas en los términos de los considerandos, por todos, 1 y 10, así como de conformidad con lo previsto en el artículo 1 del RGPD.

Dentro de la gestión del cumplimiento del RGPD se encuentra la gestión del riesgo, sobre la que pivota la seguridad de la información y no al revés.

(...)

BCE alega que las medidas de seguridad inicialmente implantadas por RSI constan en el contrato de encargo firmado con RSI y que los atacantes podrían tener credenciales legítimas para el acceso y que el ataque no se debe a la debilidad de los sistemas implantados.

Con carácter previo hemos de remitirnos a los hechos probados y a la descripción de la brecha de datos personales para entender cómo y por qué se ha producido la brecha de datos personales.

En cuanto a las medidas de seguridad que se encuentran recogidas en el “Acuerdo de modificación de la cláusula de protección de datos de los contratos de prestación de servicios”, al mencionarse la referencia a las medidas de seguridad se produce una remisión a las que constan Anexo B- Medidas de Seguridad al Acuerdo de modificación de la cláusula de protección de datos de los contratos de prestación de servicios.

Pues bien, del examen pormenorizado de la cita de las mismas, pues desconocemos el desarrollo de aquellas en relación con las medidas concretas implantadas, podemos comprobar de nuevo que son medidas que se refieren de manera general a la seguridad de la información y no a la protección de datos (...), cuestión sustancialmente distinta de la protección de datos. (...). Una política es un instrumento central y director de una organización en el que el responsable aborda sus objetivos y establece procedimientos, recursos y mecanismos para llevarlo a cabo y que precisa un desarrollo posterior pormenorizado. No es lo mismo abordar la mera seguridad de

la información que abordar la protección de un derecho fundamental cual es la protección de datos en atención al foco y finalidad de cada una de ellas.

A mayores, el hecho de que en un contrato de encargo figure un listado de medidas (además en el caso concreto medidas de seguridad de la información) no implica que las mismas garanticen una seguridad apropiada conforme determina el artículo 5.1.f) del RGPD, porque habrá que estar al enfoque en la protección de los derechos y libertades de los interesados y las medidas implementadas no tienen por qué servir al cumplimiento de tal objetivo si no han sido diseñadas e implementadas desde la perspectiva que exige el RGPD.

“QUINTA. SOBRE LA PRETENDIDA VULNERACION DEL ARTICULO 5.1.f) DEL RGPD”

BCE considera la contradicción en la que incurre el Acuerdo de Inicio al indicar que *“la identificación de una brecha de datos personales no implica la imposición de una sanción de forma directa por esta Agencia, ya que es necesario analizar la diligencia de responsables y encargados y las medidas de seguridad aplicadas”*, cuando posteriormente entiende infringido el artículo 5.1.f) como consecuencia del mero hecho de que la brecha haya tenido lugar.

Sobre este particular nos remitimos al fundamento de derecho IV explicativo de la concurrencia de la infracción del artículo 5.1.f) del RGPD en este caso concreto, donde se motiva pormenorizadamente que la infracción no se ha cometido por el mero resultado de pérdida de confidencialidad, aún cuando se trata de una infracción de resultado.

La Sentencia del Tribunal Constitucional (STC) 292/2000 con ocasión de su análisis sobre el *“contenido”* del derecho fundamental a la protección de datos alude al poder de disposición y control que incumbe al titular de los datos sobre el uso o usos posibles de sus datos por un tercero. El Fundamento de Derecho séptimo, señala:

“[...] resulta que el contenido del derecho fundamental a la protección de datos consiste en un poder de disposición y de control sobre los datos personales que faculta a la persona para decidir cuáles de esos datos proporcionar a un tercero, sea el Estado o un particular, o cuáles puede este tercero recabar, y que también permite al individuo saber quién posee esos datos personales y para qué, pudiendo oponerse a esa posesión o uso. Estos poderes de disposición y control sobre los datos personales, que constituyen parte del contenido del derecho fundamental a la protección de datos se concretan jurídicamente en la facultad de consentir la recogida, la obtención y el acceso a los datos personales, su posterior almacenamiento y tratamiento, así como su uso o usos posibles, por un tercero, sea el Estado o un particular.”

La obligación de confidencialidad que el artículo 5.1.f) del RGPD impone al responsable del tratamiento es una obligación de resultado, de tal manera que para que el precepto se encuentre infringido es preciso que se quiebre la confidencialidad de los datos.

Como precisa la STS de 15 de febrero de 2022, rec. de casación 7359/2020,

“La obligación de adoptar las medidas necesarias para garantizar la seguridad de los datos personales no puede considerarse una obligación de resultado, que implique que producida una filtración de datos personales a un tercero exista responsabilidad con independencia de las medidas adoptadas y de la actividad desplegada por el responsable del fichero o del tratamiento.

En las obligaciones de resultado existe un compromiso consistente en el cumplimiento de un determinado objetivo, asegurando el logro o resultado propuesto, en este caso garantizar la seguridad de los datos personales y la inexistencia de filtraciones o quiebras de seguridad (...). (el subrayado es nuestro)

Se ha de significar que el responsable del tratamiento incurre en contradicción cuando, por un lado, considera que no ha existido vulneración a la normativa de protección de datos y estimando que todo se debe reconducir al archivo del expediente, mientras que por otro, confirma e indica que consta evidenciado en el expediente “que el atacante podía acceder a los datos, pero en ningún caso alterarlos,...”; (...).

En cuanto a las alegaciones que reitera la parte reclamada que las infracciones imputadas respecto del artículo 5.1.f) y 32 del RGPD son idénticas puesto que nos encontramos ante un mismo hecho objeto de doble imputación, nos remitimos a lo ya indicado en fundamentos de derecho precedentes en cuanto a la propuesta de archivo de la infracción del artículo 32 del RGPD.

A la luz de lo que antecede se acredita que BCE ha vulnerado el principio de confidencialidad e integridad de los datos, principio consagrado en el artículo 5.1.f) del RGPD, infracción tipificada en el artículo 83.5.a) del RGPD.

“SEXTA. SOBRE LA PRETENDIDA VULNERACIÓN DEL ARTÍCULO 33 DEL RGPD

Respecto de las alegaciones formuladas por la parte reclamante respecto de la imputación del artículo 33 del RGPD, no es precisa ya su contestación, en tanto en cuanto, tal y como consta en los hechos probados y en los fundamentos de derecho precedentes, se propone el archivo de la infracción inicialmente imputada en atención a las circunstancias concretas del caso concreto anteriormente expresadas.

“SÉPTIMA. VULNERACIÓN DEL PRINCIPIO DE PROPORCIONALIDAD EN LA DETERMINACIÓN DE LAS SANCIONES”

BCE ha alegado que en el caso de que se considere que ha existido infracción a la normativa de protección de debe particularmente tenerse en consideración en la determinación de la sanción que pudiera imponer la aplicación del principio de proporcionalidad.

En primer lugar, BCE ha alegado que su margen bruto para 2022 es 89.518.000 €, en 2022 lugar de los 218.000.000 € reflejados en el acuerdo de inicio. BCE acredita la validez esta cuantía aportando cuentas anuales auditadas que confirman la cuantía indicada. Por esta razón, se acepta el margen bruto alegado como base de cálculo de la sanción, recalculándose en función del mismo la cuantía de la multa.

Hay que señalar que el artículo 83.1 del RGPD previene que *“Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 5 y 6 sean en cada caso individual efectivas, proporcionadas y disuasoria”*.

Las multas por tanto según se deduce del precepto invocado han de ser efectivas, proporcionadas y disuasorias para la consecución de la finalidad pretendida por el RGPD.

Es cierto, que para que dicho sistema funcione con todas sus garantías es necesario que varios elementos se desplieguen de forma íntegra y completa. La aplicación de reglas ajenas al RGPD respecto de la determinación de las multas en cada uno de los Estados miembros aplicando su derecho nacional, ya sea por circunstancias agravantes o atenuantes no previstas en el RGPD -o en la LOPDGDD en el caso español al permitirlo el propio RGPD-, restaría efectividad al sistema que perdería su sentido, su finalidad teleológica, la voluntad del legislador, resultando que las multas impuestas por distintas infracciones dejarían de ser efectivas, proporcionadas y disuasorias. Y de esta forma también se hurtaría a los interesados de la garantía efectiva de sus derechos y libertades, debilitando la aplicación uniforme del RGPD. Se disminuirían los mecanismos de protección de los derechos y las libertades de los ciudadanos y sería contrario con el espíritu del RGPD.

El RGPD está dotado de su propio principio de proporcionalidad que ha de ser aplicado en sus estrictos términos.

En cuanto al principio de proporcionalidad de las sanciones, la Audiencia Nacional en numerosas sentencias ha señalado que el principio de proporcionalidad no puede sustraerse al control jurisdiccional, pues el margen de apreciación que se otorga a la Administración en la imposición de sanciones dentro de los límites legalmente previstos, debe ser desarrollado ponderando en todo caso, las circunstancias concurrentes, al objeto de alcanzar la necesaria y debida proporción entre los hechos imputados y la responsabilidad exigida, dado que toda sanción, debe determinarse en congruencia con la entidad de la infracción cometida y según un criterio de proporcionalidad en relación con las circunstancias del hecho. De modo que la proporcionalidad constituye un principio normativo que se impone a la Administración y que reduce el ámbito de sus potestades sancionadoras.

Pues bien, de conformidad con las circunstancias que concurren en el presente caso, las cuales han sido evaluadas meticulosa y convenientemente, la presente resolución no vulnera el principio de proporcionalidad en la determinación de las sanciones impuestas, resultando ponderada y proporcionada a la gravedad de la infracción cometida, la importancia de los hechos, así como las circunstancias tenidas en cuenta para graduar la sanción, sin que se aprecien razones que justifiquen aún más la

minoración efectuada, sobre todo teniendo en cuenta la cuantía a la que pueden ascender dichas sanciones de conformidad con el art. 83.5 del RGPD, que prevé para la infracción del artículo 6.1 del RGPD, *“con multas administrativas de 20.000.000€ como máximo o, tratándose de una empresa, de una cuantía equivalente al 4% como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía”*.

En el presente caso, la entidad investigada es una gran empresa dentro de su sector de actividad; de conformidad con el hecho probado vigésimo primero, su volumen de negocio (margen bruto) durante el ejercicio de 2022 ascendió a 89.518.000 €, resultando que la multa impuesta por la infracción del artículo 5.1.f) del RGPD asciende a la cantidad de 6.159 € que estaría en tramo inferior de la posible multa administrativa que pudiera imponerse al responsable del tratamiento y muy lejos del 4% como máximo del volumen de negocio total anual global del ejercicio financiero anterior teniendo en consideración el volumen de negocio.

- Considera BCE en lo que se refiere a la circunstancia derivada de la naturaleza, gravedad y duración de la infracción que se toma como agravante la propia referencia al precepto objeto de la infracción.

Sin embargo, tal argumento no puede aceptarse por inconsistente; de facto lo que se trata de poner en evidencia es que la infracción del artículo 5.1.f) afecta a uno de los principios básicos en los que se basa la normativa en materia de protección de datos de carácter personal, la confidencialidad, y esa vulneración se halla acrecentada y agravada por el número de afectados por el incidente, los daños y perjuicios provocados (pérdida irreversible de poder y control de los datos personales por los clientes) y su duración, pues (...).

- Considera BCE en lo que se refiere a la intencionalidad o negligencia en la infracción, que la ausencia de diligencia en su actuación es debida de manera exclusiva a su condición de entidad financiera y, en puridad, sorprende la citada afirmación.

Teniendo en cuenta que en la conducta de BCE concurre el elemento de culpabilidad, que es indispensable para poder exigir responsabilidad sancionadora, en este caso se concreta, además, en una muy grave falta de diligencia en el cumplimiento del principio de confidencialidad de los datos de carácter personal como se ha puesto de manifiesto a lo largo del procedimiento.

RSI ha señalado que:

(...)

Además, la falta de diligencia demostrada en la conducta infractora de la que se le responsabiliza debe calificarse de muy grave; BCE está obligada en virtud del artículo 5.2 del RGPD a desplegar la actividad adecuada para cumplir los principios de protección de datos, por lo que aquí interesa, el de confidencialidad, y a estar en condiciones de demostrar su cumplimiento.

- Considera BCE que tener en consideración su actividad bancaria como agravante es una suerte de agravante objetiva; en primer término, no es una cuestión referida a la actividad concreta que desarrolla una determinada entidad, sino que la

agravante prevista en el art. 76.2.b) de la LOPDGDD opera cuando se vincule la actividad el infractor con la realización de tratamientos de datos personales y, es obvio que, en relación con el presente responsable del tratamiento, su actividad, en este concreto caso bancaria, está claramente vinculada, de manera directa, con múltiples tratamientos de datos personales que afectan a miles de clientes.

En este sentido, la Audiencia Nacional ha considerado que es correcto apreciar la agravante prevista en el art. 76.2.b) de la LOPDGDD siempre que exista la vinculación antedicha y así lo ha considerado en numerosas sentencias, entre otras la fecha 04/07/2024, (rec. 382/2022) señala con relación a la citada circunstancia que:

“Como también, cabe apreciar la agravante del carácter continuado de la infracción, recogida en el art. 76.2.a) de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales, remitiéndonos para ello cuando analizamos la aplicación del RGPD a la infracción que nos ocupa.

Como igualmente, la apreciación de la vinculación de la actividad del infractor con la realización de tratamientos de datos personales (art. 72.2.b) la Ley Orgánica 3/2018, de 5 de diciembre), debido a que la actividad de la parte recurrente está vinculada con el tratamiento de datos tanto de clientes como de terceros; es conocida la citada vinculación ya que la entidad por su actividad está en permanente contacto con clientes y terceros tratando un gran volumen de datos, lo que le impone un mayor deber de diligencia” (el subrayado es nuestro).

Por último, considera BCE que la AEPD para modular su responsabilidad no ha tenido en cuenta elementos para atenuar la misma, como elementos probatorios que acreditan el cumplimiento de los más altos estándares en materia de seguridad, ni el hecho de someter las medidas adoptadas a un sistema de auditoría periódica o que RSI solventó la vulnerabilidad en que consistió la brecha de seguridad; basta para desvirtuar lo manifestado remitirse al contenido de los hechos probados y en relación a la última cuestión esgrimida referirse a lo que indica el propio encargado del tratamiento en su escrito notificando la brecha de datos personales, de fecha 14/12/2022, y el escrito de 10/01/2023 trasladando el informe final, en los que responde a las siguientes cuestiones:

- ¿Se podría haber evitado la brecha adoptando alguna medida de seguridad adicional?

Si

- ¿Se ha producido el incidente por algún fallo deficiencia o incumplimiento de medidas de seguridad implementadas?

Si

Y en cuanto a las acciones tomadas con posterioridad al incidente:

- ¿Ha adaptado / mejorado sus procedimientos y políticas de seguridad?

No

Por tanto, la alegación formulada con relación a la vulneración del principio de proporcionalidad no puede ser aceptada.

A la vista de lo expuesto se procede a emitir la siguiente

PROPUESTA DE RESOLUCIÓN

Que por la Directora de la Agencia Española de Protección de Datos se sancione a BANCO COOPERATIVO ESPAÑOL, S.A. con NIF **A79496055**,

- Por la presunta infracción del artículo 5.1.f) del RGPD, tipificada en el artículo 83.5.a) del RGPD, con multa de 6.159 € (SEIS MIL CIENTO CINCUENTA Y NUEVE euros).

Que por la Directora de la Agencia Española de Protección de Datos se proceda al archivo, respecto de BANCO COOPERATIVO ESPAÑOL, S.A. con NIF **A79496055**, de

- Por la presunta infracción del artículo 32.1 del RGPD, tipificada en el artículo 83.4.a) del RGPD.
- Por la presunta infracción del artículo 33 del RGPD, tipificada en el artículo 83.4.a) del RGPD.

Asimismo, de conformidad con lo establecido en el artículo 85.2 de la LPACAP, se le informa de que podrá, en cualquier momento anterior a la resolución del presente procedimiento, llevar a cabo el pago voluntario de la sanción propuesta, lo que supondrá una reducción de un 20% del importe de la misma. Con la aplicación de esta reducción, la sanción total quedaría establecida en 4.927€ (CUATRO MIL NOVECIENTOS VEINTISIETE euros) y su pago implicará la terminación del procedimiento, sin perjuicio de la imposición de las medidas correspondientes. La efectividad de esta reducción estará condicionada al desistimiento o renuncia de cualquier acción o recurso en vía administrativa contra la sanción.

En caso de que optara por proceder al pago voluntario de la cantidad especificada anteriormente, de acuerdo con lo previsto en el artículo 85.2 citado, deberá hacerla efectiva mediante su ingreso en la cuenta restringida nº IBAN: **ES00-0000-0000-0000-0000-0000 (BIC/Código SWIFT: CAIXESBBXXX)** abierta a nombre de la Agencia Española de Protección de Datos en la entidad bancaria CAIXABANK, S.A., indicando en el concepto el número de referencia del procedimiento que figura en el encabezamiento de este documento y la causa, por pago voluntario, de reducción del importe de la sanción. Asimismo, deberá enviar el justificante del ingreso a la Subdirección General de Inspección para proceder a cerrar el expediente.

En su virtud se le notifica cuanto antecede, y se le pone de manifiesto el procedimiento a fin de que en el plazo de DIEZ DÍAS pueda alegar cuanto considere en su defensa y presentar los documentos e informaciones que considere pertinentes, de acuerdo con el artículo 89.2 de la LPACAP.

R.R.R.

INSPECTOR/INSTRUCTOR

ANEXO

Índice del expediente EXP202400072

(...)

>>

SEGUNDO: En fecha 21 de diciembre de 2024, la parte reclamada ha procedido al pago de la sanción en la cuantía de **4.927,00 euros** haciendo uso de la reducción prevista en la propuesta de resolución transcrita anteriormente.

TERCERO: El pago realizado conlleva la renuncia a cualquier acción o recurso en vía administrativa contra la sanción, en relación con los hechos a los que se refiere la propuesta de resolución.

FUNDAMENTOS DE DERECHO

I

Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), es competente para iniciar y resolver este procedimiento la Presidencia de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *"Los procedimientos tramitados por la Agencia Española de Protección de Datos se registrarán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos."*

II

Terminación del procedimiento

El artículo 85 de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en lo sucesivo LPACAP), bajo la rúbrica *"Terminación en los procedimientos sancionadores"* dispone lo siguiente:

"1. Iniciado un procedimiento sancionador, si el infractor reconoce su responsabilidad, se podrá resolver el procedimiento con la imposición de la sanción que proceda."

2. Cuando la sanción tenga únicamente carácter pecuniario o bien quepa imponer una sanción pecuniaria y otra de carácter no pecuniario pero se ha justificado la improcedencia de la segunda, el pago voluntario por el presunto responsable, en cualquier momento anterior a la resolución, implicará la terminación del procedimiento, salvo en lo relativo a la reposición de la situación alterada o a la determinación de la indemnización por los daños y perjuicios causados por la comisión de la infracción.

3. En ambos casos, cuando la sanción tenga únicamente carácter pecuniario, el órgano competente para resolver el procedimiento aplicará reducciones de, al menos, el 20 % sobre el importe de la sanción propuesta, siendo éstos acumulables entre sí. Las citadas reducciones, deberán estar determinadas en la notificación de iniciación del procedimiento y su efectividad estará condicionada al desistimiento o renuncia de cualquier acción o recurso en vía administrativa contra la sanción.

El porcentaje de reducción previsto en este apartado podrá ser incrementado reglamentariamente.”

III

Pago voluntario

De conformidad con lo dispuesto en el citado artículo 85 de la LPACAP, en la propuesta de resolución notificada se le permitía llevar a cabo el pago voluntario de la sanción propuesta, lo que supondría la reducción de un **20% de su importe**. Con la aplicación de esta reducción, la sanción quedaría establecida en **4.927,20 euros** y su pago implicará la terminación del procedimiento, sin perjuicio de la imposición de las medidas correspondientes.

Tras la citada propuesta de resolución, y antes de que se dictase resolución por parte de esta autoridad, la parte reclamada, en fecha 21 de diciembre de 2024, procedió a realizar el pago voluntario, acogándose a la reducción del 20% y renunciado a cualquier acción o recurso en vía administrativa.

Debe tenerse en cuenta que, de acuerdo con los preceptos de la LPACAP, así como de la jurisprudencia del alto tribunal en esta materia, el ejercicio del pago voluntario por el presunto responsable no exime a la administración de la obligación de resolver y notificar todos los procedimientos, cualquiera que sea su forma de iniciación. De igual forma, el artículo 88 de la citada norma establece que la resolución que ponga fin al procedimiento decidirá todas las cuestiones planteadas por los interesados y aquellas otras derivadas del mismo.

Por lo tanto, de acuerdo con la legislación aplicable y valorados los criterios de graduación de las sanciones cuya existencia ha quedado acreditada, la Presidencia de la Agencia Española de Protección de Datos **RESUELVE**:

PRIMERO: DECLARAR la comisión de las infracciones y CONFIRMAR las sanciones determinadas en la parte dispositiva de la propuesta de resolución transcrita en la presente resolución.

La suma de las citadas cuantías arroja una cantidad total de **6.159,00 euros**.

Tras haber procedido la parte reclamada al pronto pago, aunque sin reconocimiento de responsabilidad, se procede, en virtud del artículo 85 de la LPACAP, a la reducción de un 20% del total mencionado, lo cual supone la cantidad definitiva de **4.927,20 euros**.

SEGUNDO: DECLARAR la terminación del procedimiento **EXP202400072**, de conformidad con lo establecido en el artículo 85 de la LPACAP.

TERCERO: NOTIFICAR la presente resolución a **BANCO COOPERATIVO ESPAÑOL, S.A.**.

CUARTO: De acuerdo con lo previsto en el artículo 85 de la LPACAP que condiciona la reducción por pago voluntario al desistimiento o renuncia de cualquier acción o recurso en vía administrativa, por parte de la presente autoridad se acepta la renuncia expresamente manifestada por la parte reclamada, no cabiendo en consecuencia la interposición de recurso potestativo de reposición frente a la presente resolución, todo ello sin perjuicio de la posibilidad de acudir a la vía jurisdiccional contencioso-administrativa.

En consecuencia, teniendo en cuenta lo dispuesto en el artículo 90 de la LPACAP, dado que no cabe ningún recurso en vía administrativa al haber renunciado expresamente, la presente resolución será plenamente ejecutiva a partir de la notificación de la misma.

No obstante, conforme a lo previsto en el artículo 90.3 a) de la LPACAP, se podrá suspender cautelarmente la resolución firme en vía administrativa si el interesado manifiesta su intención de interponer recurso contencioso-administrativo. De ser éste el caso, el interesado deberá comunicar formalmente este hecho mediante escrito dirigido a la Agencia Española de Protección de Datos, presentándolo a través del Registro Electrónico de la Agencia [<https://sedeagpd.gob.es/sede-electronica-web/>], o a través de alguno de los restantes registros previstos en el art. 16.4 de la citada Ley 39/2015, de 1 de octubre. También deberá trasladar a la Agencia la documentación que acredite la interposición efectiva del recurso contencioso-administrativo. Si la Agencia no tuviese conocimiento de la interposición del recurso contencioso-administrativo en el plazo de dos meses desde el día siguiente a la notificación de la presente resolución, daría por finalizada la suspensión cautelar.

De conformidad con lo establecido en el artículo 50 de la LOPDGDD, la presente Resolución se hará pública una vez haya sido notificada a los interesados.

968-15012025

Olga Pérez Sanjuán

La Subdirectora General de Inspección de Datos, de conformidad con el art. 48.2 LOPDGDD, por vacancia del cargo de Presidencia y Adjunta